

Network Risk Estimation: A Risk Estimation Paradigm for Cyber Networks

ARDA BAYER, Rice University George R Brown School of Engineering, United States

DAVID MALUF, Cisco Systems Inc, United States

BEHNAAM AAZHANG, Rice University George R Brown School of Engineering, United States

Cyber networks are fundamental to many organizations' infrastructure, and the size of cyber networks is increasing rapidly. Risk measurement of the entities/endpoints that make up the network via available knowledge about possible threats has been the primary tool in cyber network security. However, the dynamic behavior of the entities and the sparsity of risk-measurable points are limiting factors for risk measurement strategies, which results in poor network visibility considering the volatility of cyber networks. This work proposes a Bayesian approach to network security, called Network Risk Estimation (NRE), which operates on top of existing risk measurements. NRE extracts relationships among system components from the network connection data, models risk propagation based on the learned relationships, and refines the estimates whenever risk measurements are provided. In this work, (i) the risk estimation scheme is proposed, (ii) an application of quantitative risk estimates is devised, (iii) descriptiveness of the risk estimates are compared with a pure risk measurement alternative and (iv) low computational complexity of the proposed method is illustrated capable of real-time deployment. NRE is ultimately a quantitative data-driven tool that can be used to add security aspects to existing network functions, such as routing, and it provides a robust description of the network state in the presence of threats, capable of running in real-time.

CCS Concepts: • **Security and privacy** → *Formal security models*.

Additional Key Words and Phrases: Cyber network security, quantitative risk assessment, risk measurement, functional connectivity, kalman filter

ACM Reference Format:

Arda Bayer, David Maluf, and Behnaam Aazhang. 2026. Network Risk Estimation: A Risk Estimation Paradigm for Cyber Networks. *ACM Trans. Priv. Sec.* 29, 4, Article 38 (November 2026), 29 pages. <https://doi.org/10.1145/3834769>

1 Introduction

Cyber networks play a crucial role in the functioning of many organizations. A cyber network, or network as short, is essentially any interconnection of individual devices referred to as “entities” or “endpoints” that communicate with each other or make their communication possible. Typical examples of networks are (i) domestic networks (smartphones, TVs, lighting systems, etc.), (ii) enterprise networks (consisting of users, servers, and routers, as depicted in Figure 1), (iii) industrial networks (e.g., sensors that gauge machine performance and communicate it to a Command and Control Center), and also (iv) networks of devices at hubs such as airports and malls. Recent

Authors' Contact Information: Arda Bayer (corresponding author), Electrical and Computer Engineering, Rice University George R Brown School of Engineering, Houston, Texas, United States; e-mail: ab126@rice.edu; David Maluf, Cisco Systems Inc, San Jose, California, United States; e-mail: dmaluf@cisco.com; Behnaam Aazhang, Electrical and Computer Engineering, Rice University George R Brown School of Engineering, Houston, Texas, United States; e-mail: aaz@rice.edu.



This work is licensed under a Creative Commons Attribution 4.0 International License.

© 2026 Copyright held by the owner/author(s).

ACM 2471-2566/2026/11-ART38

<https://doi.org/10.1145/3834769>

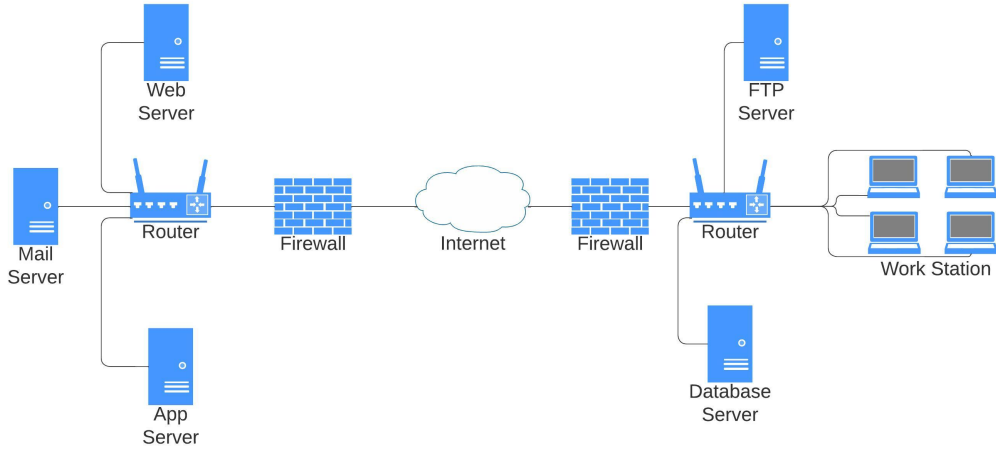


Fig. 1. An enterprise network [9] consisting of users, servers and routers. The interconnection of these entities makes up the network topology, which indicates existing direct communication channels. The network topology of a cyber network is the starting point of *Risk Estimation*.

advancements in technologies such as wireless, the **Internet of Things (IoT)**, and increased adoption of cloud computing have rapidly increased the effective size of the ultimate cyber network, where previously mentioned networks are frequently brought together. Accordingly, studies indicate that the size of the ultimate cyber network, coupled with the cloud, is increasing rapidly and poses a challenge when assessing the network regarding security [12].

Risk assessment, which is the general process of evaluating security posture in accordance with established frameworks, is the primary tool of cyber network security against countless threats [1, 2, 29, 32]. Cyber networks make up the infrastructure of many organizations and institutions, making them attractive targets for malicious attacks. A typical attack targeted at a cyber network works from the most vulnerable endpoint to its target. Attackers strive to exploit any weaknesses, and defenders try to patch the inherent vulnerabilities of their system components [25]. Against a wide variety of vulnerabilities the status quo of cyber network security has been *risk measurements*, which are the direct observables of compromise or threat, with a unifying notion of risk for a selection of vulnerabilities.

The term *risk*, sometimes called vulnerability score [29, 33], is used to quantify the expected loss if a security breach were to occur while considering the likelihood of that breach [25, 32, 34]. The current defenses for cyber networks measure the risks in a principled way by prioritizing vulnerabilities based on their associated costs and leveraging existing knowledge about the threat to estimate the likelihood of that threat [29]. Accordingly, a cyber security system that gathers information about entities and quantifies network vulnerability is a risk measurement system that gauges the cyber network's risk through available entities. Some examples of risk measurement tools are antivirus software, **intrusion detection systems (IDSs)**, and network endpoint analytics tools [12].

Since entities are ultimately responsible for the risk at the network level, the risk measurement practice can be viewed as a way to probe the vulnerability of the cyber network through available entities. However, even with the ideal risk measurements, in practice, the risk-measurable entities are generally a small portion of the network, and the growing size of the network, along with

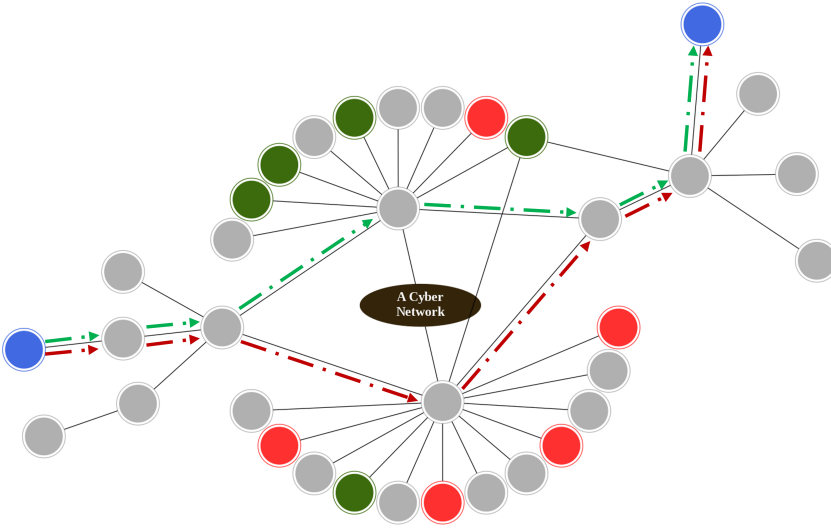


Fig. 2. An application of risk estimation on a cyber network. The graph gives the network topology where each node is an entity, and an edge indicates an allowed communication channel. Red entities are measured to have relatively higher risks, green entities have low measured risks, and blue entities desire to communicate. Two possible routes are depicted via green and red dashed arrows. For safe routing, the green path is chosen over the red one since measured entities in the vicinity have less risk.

changing entity behavior, are currently limiting factors of risk measurement practice in cyber network security [1, 29].

In this work, we distinguish between risk measurement and *risk estimation*. Risk measurement refers to direct, potentially noisy indicators of compromise or threat (e.g., IDS alerts or entity anomaly scores). Risk estimation, in contrast, refers to the inference of latent network-wide risk states by integrating measurements with structural and dynamical models of entity interactions. The broader term risk assessment is used when referring to the general process of evaluating security posture in accordance with established frameworks. We propose a scalable and data-driven risk estimation paradigm, referred to as “**Network Risk Estimation (NRE)**”, which is designed to address the aforementioned challenges. The proposed system works within a probabilistic framework where a risk distribution on entities is estimated using (1) *the connection data*, that is defined in Section 2, and (2) the risk measurements whenever and wherever provided. To our knowledge, this is the first work to model risk propagation based on entity relationships. The premise of the *NRE* is that the threat will propagate from the entity that is the threat’s source to the entities associated with it. This premise lays out the spatial -across entities- and temporal -across time- dynamics of the risk propagation model of *NRE*. The result is an estimated probability distribution of risks among entities over time.

The probabilistic risk estimates given by the proposed system can be used to (a) assess the network security quantitatively and (b) add security aspect to network-related functions. For instance, entities with high risks can be identified as weak points in the network. Alternatively, as a more elaborate network management action, the safety aspect can be added to packet routing as illustrated in Figure 2, which is briefly discussed in Section 5.2. Our contributions are (i) entity relationship modeling from available connection data, (ii) partitioning of the network via discovered entity relationships, (iii) explicit probabilistic estimation of entity risks, (iv) and an application of these estimates in network management.

The rest of the article is organized as follows. Section 2 briefly summarizes the related work in risk analysis, risk measurement approach to vulnerability assessment, and network modeling for intrusion detection. Section 3 formally states the problem of interest, defines the risk framework, and discusses the limitations of the proposed approach. In Section 4, the details of the proposed method are provided. Finally, Section 5 presents (1) the overall risk estimation process and the results on the public datasets, (2) a direct application of the produced risk estimates, (3) a particular proof of concept experiment designed for comparison with the alternative method, and (4) the running time complexity analysis.

The implementation of the proposed NRE framework is publicly available as archived research software at <https://doi.org/10.5281/zenodo.21520902> [6], with the development repository maintained at <https://github.com/ab126/NRE>.

2 Related Work

Risk Assessment. The subject of risk assessment is well-established, and it is common to many engineering designs [4]. There exist standards for risk assessment regarding network security that have been set from an organizational standpoint. ISO 31000 [21] lays out general guidelines for organizations of any kind for the purpose of assessing the risks that may hinder the organization's normal operation. These guidelines set the standard for risk management and give general instructions to deal with organizational risks where risk is essentially defined the same as in this work; the likelihood of a threat times the impact. However, it lacks the specificity to be directly applied to a cyber network. For example, cloud computing is a substantial cyber network instance that is extremely dynamic and volatile. For the cloud, these standards were criticized for being unable to cover the cloud environment's dynamic nature, and a proactive method was suggested [1]. In accordance with this shortcoming, some qualitative and quantitative risk assessment work has been dedicated to cloud computing [1, 2, 34, 35]. Among these studies, "Quantitative Impact and Risk Assessment Framework" [34] presents a framework that relies on the consensus of an expert team on the impacts of various risks and security reports in estimating the likelihood which is used to get a measurement of risks. Its main drawback is that it fails to be adaptive due to the reliance on expert discussion and lack of use of real-time network data. Another work that was aimed to quantify risks in a cloud environment is "Cyber Supply Chain Cloud Risk Assessment" [1], which similarly follows the ISO 31000 guidelines and outlines a quantitative risk assessment framework with an emphasis on the supply chain side of the cloud. This work puts forth the idea of making use of the topological information in supply-side components of the cloud service and uses probability distributions to model the uncertainty inherent in calculating the risks. However, this risk measurement approach is also not fully data-driven in the sense that it still requires cloud service provider stakeholders' knowledge and intervention to produce quantitative risks for the whole network. The authors also point out the need for a "dynamic and adaptive" risk assessment technology for the cloud environment as future needs [1].

Intrusion Detection. The studies mentioned so far can be treated as direct risk measurement practices on cyber networks where the outcome is the risk values. However, there are also works done on indirect risk measurements that deduce the likelihood part of the risk for a particular threat. The most common studies of this category are **Intrusion Detection Systems (IDSs)** that are developed for various cyber-physical networks against certain threats. For the intrusion detection problem, there exist labeled network data, called herein as *connection data*, which consists of the collection of communication sessions between pairs of entities called *flows*. A collection of descriptors called *flow features* can be extracted from raw bits making up the flows [37], after which the intrusion detection problem becomes a classification problem on the flows. An example of such an IDS is given by Wu *et. al.* where the flows are converted into doc-matrix format based on

the presence of particular intervals of flow features, which are then used in the classification of flows [43].

Graph Models for Network Risk Inference. Another approach for modeling intrusion detection has been the incorporation of network topology into the detection task via graph structure. Entity relationships gathered from connection data have previously been summarized in a “Communication Graph” [28] where nodes are the entities and edges are present if two respective nodes have participated in a flow. In their work, after obtaining the communication graph, the intrusion detection problem boils down to an edge partitioning problem on the communication graph, which has been solved by transforming it to a canonical node partitioning problem on the dual graph [28]. Variants of the communication graph have been studied in intrusion detection with the same idea of explicitly using entity relationships (see Ref. [13] for a survey). For instance, different **graph neural network (GNN)** architectures were designed by *Chang et al.* to make the best use of both structural information in the graph, the entity relationships, and the information in the flow descriptors [10]. GNN models gained interest after their demonstrated higher performance in intrusion detection and risk inference problems.

Recent work has applied GNNs to cybersecurity tasks by leveraging the relational structure of communication and attack graphs. Surveys show that GNNs can capture topological and statistical dependencies for intrusion detection and malicious behavior classification across IoT and network traffic datasets [47]. These approaches typically learn node or edge representations from communication graphs and flow features and are primarily evaluated on intrusion or anomaly detection objectives, producing categorical predictions such as attack type or benign/malicious labels [16]. While GNNs are expressive and effective for representation learning, their outputs are often point estimates and lack an explicit probabilistic interpretation of risk. Moreover, training such models generally requires large labeled datasets and retraining to adapt to evolving network dynamics.

Despite the vast modeling perspectives, these studies from the intrusion detection literature are essentially *risk measurements* for particular threats, such as “Distributed Denial of Service” or “Brute Force” attacks [37], from risk assessment [4] point of view. Consequently, as mentioned in Section 1, this approach to cyber network security suffers from limited risk-measurable entities, the dynamic nature of the network in terms of changing entity behavior, and the addition of new entities. In contrast, the proposed NRE framework explicitly models risk as a latent continuous-valued state that evolves over time, integrates asynchronous risk measurements, and provides uncertainty quantification through a Bayesian filtering formulation. Rather than learning a discriminative mapping from graph structure to labels, NRE leverages graph structure as a dynamical risk propagation model, enabling real-time inference even in low-label or partially observable regimes.

Bayesian and Uncertainty-Aware Approaches in Cyber Defense. A parallel line of research has emphasized probabilistic and Bayesian methods for cyber network security, particularly in settings with partial observability and uncertain measurements [11, 27, 44]. These works model security-relevant variables such as attacker presence, system compromise, or alert credibility as random variables and use Bayesian inference to update beliefs as new evidence becomes available. Such approaches have been applied to cyber-physical system threat inference [11], attack graph analysis [27], and cyber situational awareness [44], highlighting the importance of uncertainty quantification for robust decision making.

However, many existing Bayesian cyber defense models rely on predefined attack graphs, expert-curated priors, or static system models, which limits scalability and adaptability in large, dynamic networks. The proposed NRE framework differs by learning entity relationships directly from connection data and embedding them into a linear dynamical system that supports principled Bayesian filtering. This enables continuous risk estimation with quantified uncertainty while remaining computationally efficient for real-time operation.

Summary Positioning. In summary, existing approaches either focus on direct risk measurement, discriminative intrusion detection, or probabilistic reasoning with fixed system models, whereas NRE bridges these perspectives by combining data-driven relationship inference with Bayesian risk propagation to produce interpretable, uncertainty-aware network-wide risk estimates.

3 Problem Statement

In the security setting, network assessment is done in terms of risk measures [15, 25, 34]. Once the risks of individual threats are identified, defensive measures can be taken [34, 35]. As an example, if the greatest risk against the network is an exploit due to an older version of the software, a software update can be administered to the respective entities in the network.

Accordingly, we start the risk estimation process by identifying the threat γ . The threat γ is identifiable, meaning given an outcome $\omega \in \Omega$ that describes the state of the cyber-network, one can conduct a test with related entities and decide whether the threat γ is present or not. Let Ω denote the set of all identifiable outcomes. Next, we can talk about a probability measure $P : \mathcal{F} \rightarrow \mathbb{R}$ on Ω that quantifies the *likelihood* of each outcome associated with the threat γ , where $\mathcal{F}$ is a σ -algebra on Ω . For instance, if the threat γ is a known virus, and let $S_A \subset \Omega$ denote the set of outcomes where a certain entity A is compromised by the virus γ , then $P(S_A)$ quantifies the likelihood of A being infected by the virus γ . Since the threat γ is identifiable, $P(S_A)$ might be hard to evaluate, but is a well-defined quantity. In this work, we define the *risk* as a measure R on the outcomes associated with the threat γ that quantifies likelihood just like the probability measure P . However, we do not require R to be normalized as the probability measure is, $P(\Omega) = 1$.

So, the target is the risk measure R on the identifiable outcomes of the threat γ , which knowing $R(\omega)$ for all outcomes $\omega \in \Omega$ would perfectly describe all that is needed to know about the threat γ . However, the set of all identifiable outcomes Ω can be countably infinite, in which case the direct estimation of R becomes infeasible. Instead, we seek a tractable version of the risk measure R that we refer to as the *entity risks*. Following the virus example and given the network topology, we define the entity risk R_A for each entity A as “the risk measure of the outcomes S_A where entity A is compromised by the threat γ ”, $R_A = R(S_A)$. This way, our target is a countable number of variables given the network of interest. If one weighs the likelihood described by the entity risks R_A with the *impact* of what would be if the entity A was compromised by the threat γ , we recover the risk definition used in related work, i.e., the *likelihood * impact* [21, 25, 32, 34] where impact can be measured in dollar amounts as an example.

The goal of this work is to estimate the entity risks for each entity in the network, given (1) some risk measurements on a set of entities and (2) the connection data, the flows, that capture the activity in the network. Phrased in the framework of probability theory, the problem tackled here is to find the probability distribution of entity risks given sparse risk measurements on some entities, red and green entities in Figure 2, and connection data. It is implied that the risk measurements, whatever the source be, are mapped to the same “risk units” or scale according to the same standard.

When risks are forged for every entity, network management becomes clear which is an advantage of risk estimation. For instance, given two entities that want to communicate, e.g., blue entities in Figure 2, one can find the “most trusted path” to route the packets in between, which is referred to as safe routing (Section 5.2). One way to do this is to minimize the expected maximum risk along the path over all possible paths between two entities, intuitively picking the green path instead of the red one in Figure 2. This application of the proposed risk estimation method is illustrated in Section 5.2. Another use case is that the “high risk” entities in the network can be immediately identified and can be used in devising new measurement strategies or in implementing security policies such as quarantining.

Limitations and Scope. The limitations posed by the risk estimation formulation are unidentifiable threats, such as zero-day exploits. It is not clear whether the sample space Ω is even a set for these threats. Another limitation is partially observable threats, i.e., threats that are poorly captured or not captured at all by the available information on the network. In this case, the risk estimates computed will not be representative of the actual threat. Observability comes into play through the measurements and the connection data, and a criterion for the observability is given in Section 4.2.4. The observability limitation is detrimental, especially when large dynamic networks are considered, such as cloud and IoT, putting a bound on the scope of the network that can be risk estimated, Section 4.1.1, and a lower bound on measurements that must be assisted, Section 4.2.4.

In addition, the proposed formulation assumes that entity identities and interaction structures are sufficiently stable over the estimation horizon. In highly dynamic environments, such as large-scale IoT deployments or elastic cloud infrastructures, entities may frequently join, leave, or change roles, and interaction patterns may evolve rapidly. In such cases, the definition of the entity set and the associated connection structure becomes time-varying at a rate that may violate the modeling assumptions in Sections 4.1.1 and 4.1.5. While the framework can accommodate moderate structural evolution through sequential re-estimation, frequent entity turnover or highly virtualized network infrastructures may reduce the fidelity of the inferred risk state. Therefore, the applicability of the proposed risk estimation framework is bounded by the stability and observability of the underlying entity-interaction graph. Finally, the definition of risk adopted in this work is operational and model-based, focusing on latent state inference from observable measurements rather than comprehensive organizational risk assessment. These considerations delineate the intended scope of the current framework.

4 Method

This section outlines the details of the proposed risk estimation method. The underlying premise assumed in this work is that the risk of entities will propagate through the network by the way entities influence each other. This is based on the fact that organized cyber-attacks target system vulnerabilities to gain privilege over entities [22, 29]. It is assumed herein that during this process, the exploiter leaves a footprint in the connection data/flows, referred to as the influence relationship between involved entities. With this reasoning, the first part of the proposed work is dedicated to uncovering the way entities influence each other in the network, which is the basis for the *functional connectivity graph* (Section 4.1). This step summarizes the discovered entity behavioral relationships as a weighted directed graph F . In the second part, the calculated graph is used as a linear model for predicting risks, in which the risk estimates are refined with incoming measurements using a probabilistic framework (Section 4.2). Finally, in Section 4.3, real-time deployment is discussed. Although the proposed method is used in the context of cyber networks, it is generalizable to other dynamic networks for obtaining low-dimensional latent variables regarding system state.

4.1 Inference of Relationships

For the cyber networks considered in this work, it is assumed that the connection data comprises distinct flows just like NetFlow, sFlow formats [19] where a *flow* is defined as any communication between two endpoints in one session [19, 39]. These flows have multiple *flow attributes* that give additional information about flows, such as timestamp, flow duration, and number of packets in each direction, and more [23]. The goal of this step is to represent the observed association in the network with a weighted graph G .

Previously in the field of cyber-security, similar entity relationship graphs have been constructed as *communication graphs* [13, 28] where two entities have an edge if there has been at least one flow observed between them. Although the communication graph is a valid way to model the

entity relationships, we here present a more general way to devise the relationship graph, referred as the *functional connectivity graph*, encompassing the communication graph but also capable of capturing more abstract dependencies among entities.

Given the collection of flows referred as the *connection data*, first the **entities of interest (EOI)** for which the risks are to be estimated are identified. Then, the relationship among entities is analyzed in this work with respect to a single *connection parameter* derived from flow attributes where each connection parameter captures a distinct aspect of the flows. These step are given in Section 4.1.1. Once a connection parameter is chosen, discrete-time signals are formed for each entity. This process requires a synchronization step described in Section 4.1.2. Then, in Section 4.1.3, the method used for obtaining the functional connectivity graph is presented. Sections 4.1.4 and 4.1.5 discuss some of the optional but recommended steps taken to optimize the graph, which will be used as the essential model for risk prediction.

4.1.1 Selection of Entities of Interest and Connection Parameter. We start by picking the entities of interest for the risk estimation. The EOI can be set as the known internal network, or the one inferred by the node partitioning described in Section 4.1.5, which is the choice for the results presented in Section 5.1. However, one can design extensions by defining rules for entity addition, removal, and by providing prior risk estimates for the added entities (Section 4.2). For a given EOI, all entities that have observed flows with the EOI come into the risk estimation process, which is essential for dynamic networks such as IoT, cloud, and mobile networks.

After the choice of EOI, the aspect of flows to be modeled is picked, which is referred to as a *connection parameter* in this work. The connection parameter describes the attributes of the flows that the subsequent risk estimation process considers for inferring entity behavioral relationships. For instance, “Number of Packets Received” is a connection parameter derived from “Number of Packets in the Forward Direction” and “Number of Packets in the Backward Direction” flow attributes. This connection parameter quantifies the inward volume of flows for an entity. In this work, a few straightforward choices of connection parameters have been put forth. A summary of relevant connection parameters is given in Table 1.

4.1.2 Synchronization. A flow can start and end anytime in the network. Consequently, the observations about entities in connection data are asynchronous naturally. For modeling entity behaviors, working with synchronous discrete-time signals is easier. Accordingly, all the flows in a given time interval are aggregated with a custom choice of window size, yielding synchronous signals for entities.

For a chosen *synchronization window size* denoted by δ (e.g., 2 s), flow attributes for each flow in a time window are aggregated by either summing, averaging, or taking the last value depending on the connection parameter that is being used (see Table 1). As an example, if it is desired to build the entity-relationship model by the number of packets an entity receives, the **Number of Packets Received (NPR)** signal for each entity can be formed by counting the total number of packets each entity received per time-window. Similarly, if the objective is to model the flow speed, the “*Flow Speed*” signal can be computed as the mean flow speed of the flows created by each entity. This process is summarized in Figure 3, where flows of two entities are depicted on the top row, and the constructed synchronous signals for two distinct connection parameters are given below. Here, the “Activation” is another connection parameter that can be used to deduce if two entities have sent packets coincidentally or not. Synchronous samples of these signals are then used to quantify influences among entities.

4.1.3 Functional Connectivity Graph from Connection Data. After constructing synchronous signals per entity for a given connection parameter, the next step is to infer the underlying relationships

Table 1. A Summary of Connection Parameters that are Used

Connection Parameter	Description	Aggregation Method
Activation	A binary indicator denoting if an entity is sending or receiving any packets	N/A
Active Time	Mean time an entity was active before becoming idle	Average
Flow Duration	Total duration of the flows	Total
Flow Speed	Average bytes per second	Average
Header Length	Average bytes used in packet header in forward direction	Average
Idle Time	Mean time the flows were idle before becoming active	Average
Number of Active Packets	Total number of packets with at least 1 byte of packet payload in forward direction	Total
Number of Packets Received	Total number of packets in the backward direction	Total
Number of Packets Sent	Total number of packets in the forward direction	Total
Packet Delay	Average of packet Inter Arrival Time (IAT) in forward directions	Average
Packet Length	Average size of packets in forward direction	Average
Port Number	The port number used by the entity for the flow	Mode
Protocol	Flow's Internet Protocol Number (e.g. TCP:6, UDP:17, etc.)	Mode
Response Time	Average of packet Inter Arrival Time (IAT) in backward direction	Average

Each connection Parameter captures an aspect of flows involving an entity, and it is derived from flow attributes in connection data. *Aggregation Method* refers to the way flows are aggregated in the synchronization step (Section 4.1.2). The flow attributes are based on Lashkari et al. [23].

among pairs of entities. The extent of entity A influencing entity B is quantified solely from the constructed signals of entity A and B with a choice of an influence measure. The end goal of this step is *the functional connectivity graph* which is a weighted directed graph $G = (V, E, W)$ where V is the set of entities, E is the set of edges where an edge $e = (v_i, v_j)$ represent the influence of entity v_i on v_j and the respective non-negative weight $w_{ij} \geq 0$ quantify how strong the influence is for respective edge.

Once the entities are indexed, the graph $G = (V, E, W)$ is completely described by the respective *weight matrix* denoted by F where the entries are the weights when the edge is present, and 0 otherwise; $F_{ij} = \begin{cases} w_{ij} & , (v_i, v_j) \in E \\ 0 & , (v_i, v_j) \notin E \end{cases}$, as depicted in Figure 4. The superscript (t) is used to denote that the calculation of the graph was done for the time window $[t, t + \tau)$ where τ is the fixed *graph window size*. Throughout this work, the weight matrix notation, F , will be used to refer to the functional connectivity graph instead of the conventional set notation $G = (V, E, W)$.

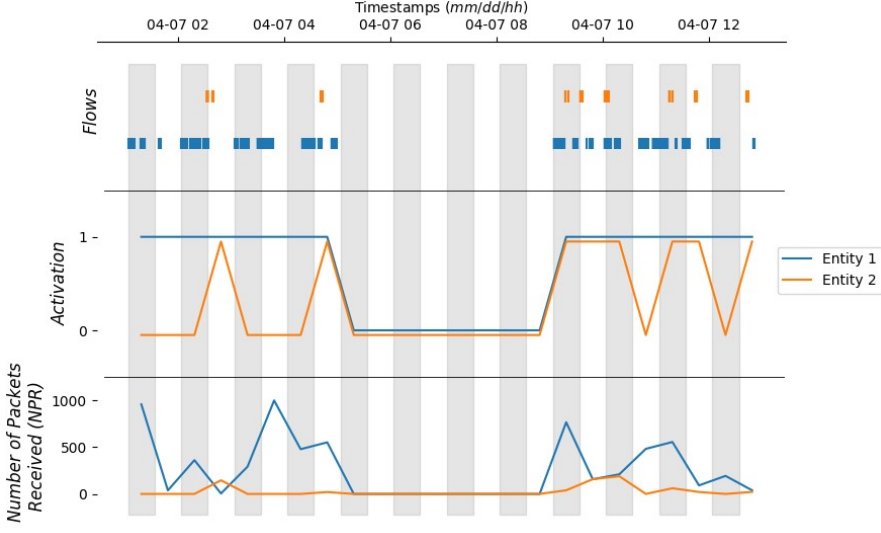


Fig. 3. An illustration of the synchronization process involving two entities. Shaded and unshaded regions denote consecutive synchronization time windows. *Flows*: Flow history of two arbitrary entities. Each tick corresponds to a flow in connection data. *Activation*: The connection parameters that lead to a signal that depicts the activities of respective entities. *Number of Packets Received (NPR)*: Another connection parameter that grants a signal indicating the number of packets an entity receives. Ultimately, the obtained signals are defined per entity and are synchronous.

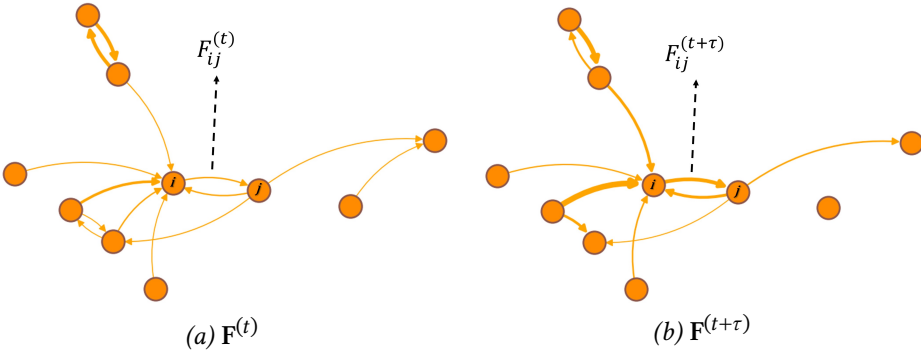


Fig. 4. A functional connectivity graph $\mathbf{f}$ that manifests the relationships among entities at two different timestamps. (a) $\mathbf{F}^{(t)}$ and (b) $\mathbf{F}^{(t+\tau)}$. For each pair of entities (i, j) , the strength of influence $F_{ij}^{(t)}$ is calculated, which results in a weighted directed graph in general. The graph evolves with time as the connections happen.

Obtaining the underlying *functional connectivity graph* out of observational data falls in the field of “Causal Discovery”, which comes with a few caveats for cyber networks. First, even if there was a unique underlying causal structure among entities in generating the connection data, the precise recovery of this structure is only possible up to a set of functional connectivity graphs that are indistinguishable without additional information [17]. Secondly and more critically, conventional causal discovery algorithms such as the Peter-Clark algorithm [17] and their variants scale terribly with the number of nodes/entities. The “Causal Discovery” is typically employed for problems

having no more than 15 nodes, whereas in this case, the number of devices/entities can easily be thousands. For these reasons, inferring the functional connectivity graph from signals obtained according to Section 4.1.2 is simplified greatly for the cyber network to what is called simple *association network* inference [20], which results in an undirected graph F . In doing so, each pair of nodes is studied independently, and the objective weights of this graph, w_{ij} , are computed using a simple similarity metric for signals on the entities. However, the risk estimation approach proposed here is suited for any functional connectivity graph inference method that might be more appealing for different scenarios.

The similarity metric that has been used for weight calculation is the “Magnitude of the Pearson Correlation Coefficient”. In quantifying the relationship, each sample of the preprocessed signal is assumed to be independent with an appropriate choice of window size in Section 4.1.2, and thus, sample-based estimation of the correlation coefficient is justified as a metric for the association. The resulting graph is undirected or equivalently graph weight matrix F is symmetric.

Let $Y_i^{(t)} = \{y_{i,1}^{(t)}, y_{i,2}^{(t)}, \dots, y_{i,N}^{(t)}\}$ denote the N samples of the synchronous signal obtained as in Section 4.1.2 for the entity i in the time window $[t, t + \tau)$. Then the functional connectivity graph for this time window obtained via the “Magnitude of the Pearson Correlation Coefficient” estimator is a symmetric weighted graph whose weight matrix’s entries are given by Equation (1) where $\text{Cov}(Y_i^{(t)}, Y_j^{(t)})$ is the sample covariance, $s(Y_i^{(t)})$ is the sample standard deviation and $\bar{y}_i^{(t)}$ is the sample mean. The edge weights are normalized such that $F_{ij}^{(t)} \in [0, 1]$ and $F_{ii}^{(t)} = 1$, for the functional connectivity graphs in the proposed risk estimation scheme. The consequence of this normalization is that an entity will maintain its risk, and the entities that influence it will add to its previous risk (see Section 4.2). The scaling of the absolute values of the risks are handled later in Section 4.2.3.

$$F_{ij}^{(t)} = |r_{ij}| = \frac{|\text{Cov}(Y_i^{(t)}, Y_j^{(t)})|}{s(Y_i^{(t)}) s(Y_j^{(t)})} \quad (1)$$

$$\text{Cov}(Y_i^{(t)}, Y_j^{(t)}) = \frac{1}{N-1} \sum_{k=1}^N (y_{i,k}^{(t)} - \bar{y}_i^{(t)})(y_{j,k}^{(t)} - \bar{y}_j^{(t)})$$

$$s(Y_i^{(t)}) = \sqrt{\frac{1}{N-1} \sum_{k=1}^N (y_{i,k}^{(t)} - \bar{y}_i^{(t)})^2}$$

$$\bar{y}_i^{(t)} = \frac{1}{N} \sum_{k=1}^N y_{i,k}^{(t)}$$

The calculated functional connectivity graph is per time-window that has been chosen, and the resulting graph $F^{(t)}$ is dynamic, and it most likely will change over time as illustrated in Figure 4. Although the inferred functional connectivity graph might resemble the network topology, i.e. the allowed communication channels between entities such as the one in Figure 2, there is a crucial difference. Distant entities in the network topology might influence each other, resulting in a significant edge in the functional connectivity graph; however, there might be no direct edge in the network topology. For this reason, it is better to work with the functional connectivity graph from risk estimation point of view.

In forming the functional connectivity graph, different metrics such as Conditional Shannon Entropy, Mutual Information [42], Directed Information [31], or Graphical Directed Information [45] can be chosen. This preference would, in general, result in a weighted directed graph $F^{(t)}$.

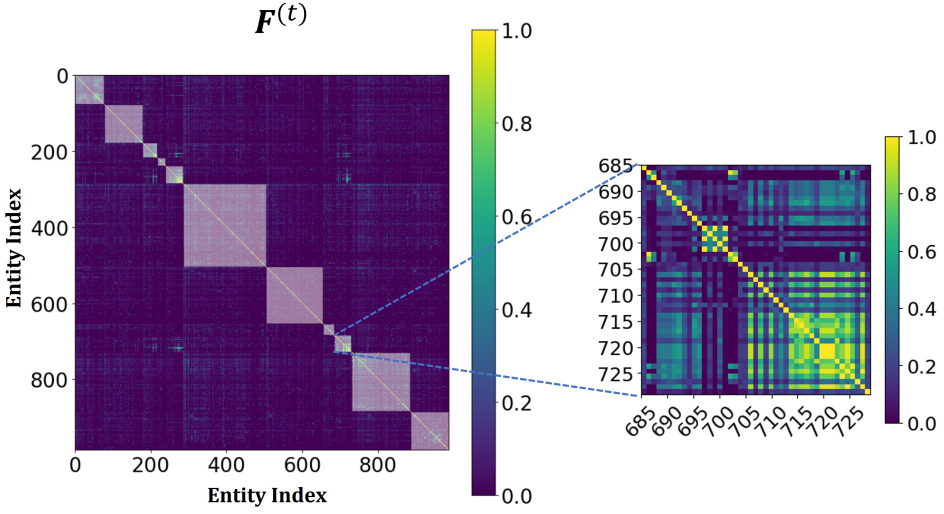


Fig. 5. Entity groups detected via spectral partitioning algorithm. *Left*: The matrix representation of the Functional connectivity graph $F^{(t)}$ for the whole network where entities are enumerated on both axes. The (i, j) th entry, or $F_{ij}^{(t)}$, is the weight quantifying how much entity i influences entity j . *Right*: A sub-network of interest. Risk estimation is solved independently on the detected entity groups.

However, the experiments presented in Section 5 are confined to the metric given by Equation (1), which leads to a symmetric graph weight matrix $F^{(t)}$. One thing that must be considered as a result of using different similarity metrics is the scaling of risks. Having unbounded values in the entries will greatly affect the risk estimation step, Section 4.2, thus we highly recommend normalizing the functional connectivity graph in one way or another. On top of the normalized functional connectivity graph $F^{(t)}$, an additional mechanism to control the scaling of risks is designed in this work which is discussed in Section 4.2.3.

4.1.4 Forget Factor. In practice, it is desired for calculated functional connectivity graph $F^{(t)}$ to have a “memory” such that the current connectivity graph carries over some of the relationships captured in previous time windows. This memory mechanism is modeled in the proposed work by Equation (2) as

$$F_s^{(t)} = (1 - \rho_f)F_s^{(t-\tau)} + \rho_f F^{(t)} \quad (2)$$

Here, ρ_f is referred to as the *forget factor*, and it controls the contribution of the past edge weight on the current functional connectivity graph. The value of ρ_f is experimentally determined by validation on the training part of the dataset. The graph $F_s^{(t)}$ is referred to as the *smoothed graph* since it will change less dramatically with time and, it can be used in place of $F^{(t)}$ from Section 4.1.5 and onwards.

4.1.5 Node Partitioning. Occasionally, the calculated functional connectivity graph having thousands of entities will be sparse due to the local activity of entities. In those cases, it is much more desirable to break the problem into smaller subproblems by isolating functionally independent groups of entities via node partitioning and treating them independently for risk calculation (Figure 5). In practice, the separated entities will have small but non-zero edge weights between them. The node partitioning approximation essentially discards these inter-group edges, which

are lost information. In order to reduce the approximation error, the node partitioning objective has been set to minimize the sum of the weights of the discarded edges, known as the “Ratio Cut” problem [18].

For the proposed method, the *spectral partitioning* algorithm has been used as the preferred partitioning method, which solves the relaxed ratio cut problem where the sum of inter-group edges is minimized with a penalty against smaller groups [18]. The partitioning can be applied until the entity groups are of the desired size, e.g., small enough to be processed in real-time. However, it must be noted that this is still an approximation, and each additional partitioning will increase the approximation error. Ultimately, spectral partitioning suggests a set of entities that can be studied independently with minimal error, which means that the risk prediction problem can be broken down into smaller, much more manageable problems in which the entities are well-connected.

4.2 Risk Propagation Model

The underlying assumption for the proposed risk propagation model is a linear model concerning how the risks propagate throughout the network. Suppose, we have the risk estimates for each entity in the network at time t represented by a column vector $\mathbf{x}_t \in \mathbb{R}^n$ where n is the number of entities. The risk propagation model assumed here can be stated as “the increase in the risk of a given entity A , is proportional to the risks of the entities that influence A and to the extent they influence A ”. In other words, if A is clearly associated with a high-risk entity, we expect A ’s risk to increase accordingly.

This idea is summarized precisely as the set of linear equations given by Equation (3), and it is illustrated in Figure 6.

$$\mathbf{x}_{t+\tau} = \mathbf{F}^{(t)} \mathbf{x}_t \quad (3)$$

Here $\mathbf{x}_t$ is the current risk estimates for the whole network at time t , $\mathbf{F}^{(t)}$ is the graph calculated from connections in time interval $[t, t + \tau)$ and $\mathbf{x}_{t+\tau}$ is predicted risks at time $t + \tau$. Another interpretation of Equation (3) is a diffusion process on the weighted graph $\mathbf{F}^{(t)}$ where the risks are diffused through the edges in accordance with the edge weights. Ultimately, the risk propagation idea summarized by Equation (3) states the temporal dynamics and spatial relationships of the entity risks, i.e., how the risks evolve in the network over time.

To give an example of the risk propagation model and the notion of entity risks, consider the threat of malicious software/virus for a cyber network. The entity risks, in this case, can be the expected cost of a given entity being compromised by the virus in dollar amounts. Antivirus countermeasures are able to tell us about the likelihood of certain entities being compromised, and consequently the associated risk, but this is not the case for the whole network. The intuition for how the virus advances among entities is essentially summarized by the saying “Tell me who your friends are, and I’ll tell you who you are”, which constitutes the risk propagation model. Accordingly, if we have an estimate of the risk distribution for every entity in the network at some point in time, then we can have an educated guess about the risk distribution for the very next time step. This insight about the risks is not covered by the antivirus countermeasures, and it has to do with the observed behavior of entities.

4.2.1 Optimal Linear Risk Estimator. Using the risk propagation model given in Equation (3), one can keep predicting the risks given the connections and initial estimate. Even though this estimate carries the intuitive idea that entities influenced by risky entities should become riskier, the risk estimates are prone to errors. As an example, a small error in the initial risk estimate and an error in the estimation of the relationship graph will lead to increasing discrepancies between

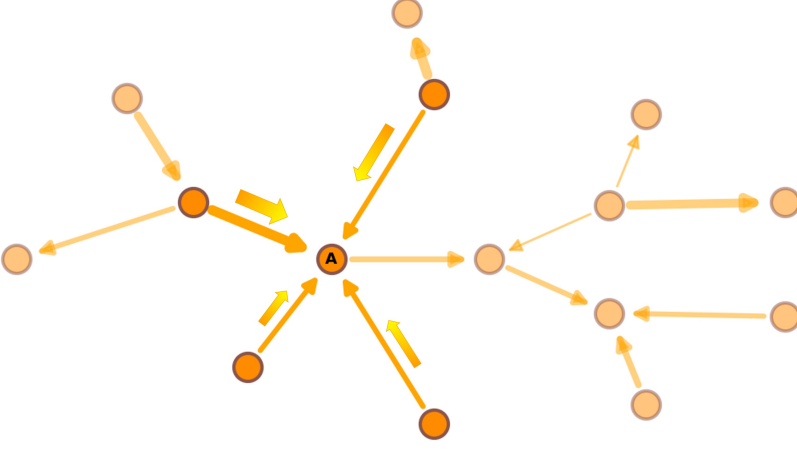


Fig. 6. Risk propagation illustration for the *network risk estimation* system. Entity **A**'s risk, which is an entry in risk vector $\mathbf{x}_t$, at the next time step is its previous risk plus the weighted sum of its neighbors' risks weighted by the edge weights given by functional connectivity graph $\mathbf{F}^{(t)}$. This risk propagation idea specifies the temporal and spatial dynamics of the risk.

the actual risks and the risk estimates over time. For this reason, the risk estimates obtained by Equation (3) are refined with the incoming risk measurements in minimum mean squared error sense, where the measurements are referred to collectively as $\mathbf{z}_t$. The resulting estimation process is also known as the discrete Kalman Filter [38]. Integration of this probabilistic framework into the risk estimation problem is crucial since it not only gives the optimal risk estimates according to the assumed model but the uncertainties of those estimates as well, in the form of error covariance matrix $\mathbf{P}_{t|t}$.

Based on Equation (3), a linear probabilistic model is assumed for the entity risks $\mathbf{x}_t$. A portion of the entities are risk-measured at time instance t , represented by $\mathbf{z}_t$.

System and Measurement Model:

$$\begin{aligned}\mathbf{x}_{t+\tau} &= \mathbf{F}^{(t)} \mathbf{x}_t + \mathbf{w}_t \\ \mathbf{z}_t &= \mathbf{H}_t \mathbf{x}_t + \mathbf{v}_t\end{aligned}\tag{4}$$

Here, $\mathbf{x}_t \in \mathbb{R}^n$ is the actual risks at the beginning of time t , $\mathbf{w}_t \sim \mathcal{N}(\mathbf{0}, \mathbf{Q}_t)$ is the system process noise which is independently normal distributed with $\mathbf{0}$ mean and diagonal covariance matrix $\mathbf{Q}_t$, $\mathbf{v}_t \sim \mathcal{N}(\mathbf{0}, \mathbf{R}_t)$ is the independently normal distributed measurement noise, $\mathbf{z}_t \in \mathbb{R}^m$ is the risk measurements and $\mathbf{H}_t \in \{0, 1\}^{m \times n}$ is the matrix that selects entities that are measured at time t . Essentially, each row of $\mathbf{H}_t$ and $\mathbf{z}_t$ corresponds to a risk measurement in the network. $\mathbf{z}_t$ contains the measured risk value, the respective row of $\mathbf{H}_t$ has a 1 in the position of the measured entity, and the rest of the entries are 0. $\mathbf{x}_t$ represents risk values of all entities in the network, which is the value desired to be estimated, whereas $\mathbf{z}_t$ are the noisy risk measurements from a usually small number of entities. In Figure 2, $\mathbf{z}_t$ corresponds to risk measurements of red and green entities, and $\mathbf{x}_t$ represent the risks of every entity; red, green, gray and blue combined.

The estimate risk distribution is described by the mean of the estimate $\hat{\mathbf{x}}_{t|t} = \mathbb{E}[\mathbf{x}_t | \mathbf{z}_0^t]$ and the error covariance matrix $\mathbf{P}_{t|t} = \mathbb{E}[(\mathbf{x}_t - \hat{\mathbf{x}}_{t|t})(\mathbf{x}_t - \hat{\mathbf{x}}_{t|t})^T | \mathbf{z}_0^t]$ where $\mathbb{E}[\cdot]$ is the expected value operator and $\mathbf{z}_0^t = \{\mathbf{z}_0, \dots, \mathbf{z}_t\}$ are all the risk measurements up to time t . Assuming the model in Equation (4) and an initial guess about the risk distribution, the linear optimal risk estimator is given recursively

by Equations (5) and (6), which is derived in A.

Predict:

$$\begin{aligned}\hat{\mathbf{x}}_{t+\tau|t} &= \mathbf{F}^{(t)} \hat{\mathbf{x}}_{t|t} \\ \mathbf{P}_{t+\tau|t} &= \mathbf{F}^{(t)} \mathbf{P}_{t|t} \mathbf{F}^{(t)T} + \mathbf{Q}_t\end{aligned}\quad (5)$$

Update:

$$\begin{aligned}\mathbf{S}_{t+\tau} &= \mathbf{H}_{t+\tau} \mathbf{P}_{t+\tau|t} \mathbf{H}_{t+\tau}^T + \mathbf{R}_{t+\tau} \\ \mathbf{K}_{t+\tau}^* &= \mathbf{P}_{t+\tau|t} \mathbf{H}_{t+\tau}^T \mathbf{S}_{t+\tau}^{-1} \\ \hat{\mathbf{x}}_{t+\tau|t+\tau} &= \hat{\mathbf{x}}_{t+\tau|t} + \mathbf{K}_{t+\tau}^* (\mathbf{z}_{t+\tau} - \mathbf{H}_{t+\tau} \hat{\mathbf{x}}_{t+\tau|t}) \\ \mathbf{P}_{t+\tau|t+\tau} &= \mathbf{P}_{t+\tau|t} - \mathbf{K}_{t+\tau}^* \mathbf{S}_{t+\tau}^{-1} \mathbf{K}_{t+\tau}^{*T}\end{aligned}\quad (6)$$

Risk distribution described by $\hat{\mathbf{x}}_{t|t}$ and $\mathbf{P}_{t|t}$ is the best linear risk estimate, in **minimum mean squared error (MMSE)** sense, in the presence of risk measurements [8]. Initial risk estimate need not be exact and can be guessed, such as uninformative uniform mean $\hat{\mathbf{x}}_{0|0} = \mathbf{1}$ and process noise for error covariance $\mathbf{P}_{0|0} = \mathbf{Q}_0$. The Kalman Filter given by Equations (5) and (6) guarantees that the estimation error will converge to zero in the case of fixed system parameters $\mathbf{F}$, $\mathbf{H}$, $\mathbf{Q}$ and $\mathbf{R}$ as long as they are accurate. If no measurement is made at a time step, then only the predict step is applied and a *posteriori* estimate becomes the same as a *a priori* estimate, $\hat{\mathbf{x}}_{t+\tau|t+\tau} = \hat{\mathbf{x}}_{t+\tau|t}$ and $\mathbf{P}_{t+\tau|t+\tau} = \mathbf{P}_{t+\tau|t}$.

4.2.2 Choice of Prior. The prior risk distribution is our estimate of the entity risks in the network. In the Bayesian setting, the observation about the entities along with risk measurements constitutes the *likelihood* and Equation (6) is the *posterior*, which is the best estimate given the observations. The source of prior can be any combination of quantifiable methods that relay information about the likelihood of compromise for the entities [14, 41] (Section 3). Specifically, we use up to 2nd order statistics, the mean, and the covariance of the entity risk priors.

An example of forging priors is to utilize the software versions that the entity uses. Older versions of software are associated with a higher probability of exploits; consequently, one model for priors can assign higher mean entity risks and variances monotonically increasing with older software versions, e.g., $\propto T^\alpha$ where T is the average software age since release and $\alpha > 0$. The priors are case-dependent, and different models can be used to produce priors representing different extents of knowledge about threats. If no information is available about the entities, a uniform prior with high variance can be used, representing no initial risk information about the entities. If the risk propagation model holds for the threat of interest and assuming observability (Section 4.2.4), then the Kalman Filter used in Equation (6) guarantees convergence regardless of the initial prior [3]. If the system is not observable, which might be the case for some large and dynamic systems, then no prior guarantees the convergence.

4.2.3 Relief Factor. The risk estimates given by Equation (6) tell us about the risk distribution in the network as a result of (i) the risk propagation model and (ii) risk measurements. Although the relative risks of entities are the more interesting aspect, without proper scaling, the risk estimates $\hat{\mathbf{x}}_{t|t}$ are unbounded. This happens when the functional connectivity graph $\mathbf{F}^{(t)}$ has eigenvalues greater than 1. From risk estimation point of view, this is an undesired effect since an entity left alone should not have unbounded risks when no additional measurements are provided. Consequently, this desired property is added to the estimation scheme by scaling the posterior estimates $\hat{\mathbf{x}}_{t+\tau|t+\tau}$ and $\mathbf{P}_{t+\tau|t+\tau}$ with what's here referred as the *relief factor* ρ_r which acts as a design parameter of the

risk estimation system.

$$\begin{aligned}\hat{\mathbf{x}}'_{t+\tau|t+\tau} &= (1 - \rho_r)\hat{\mathbf{x}}_{t+\tau|t+\tau} \\ \mathbf{P}'_{t+\tau|t+\tau} &= (1 - \rho_r)^2\mathbf{P}_{t+\tau|t+\tau}\end{aligned}\quad (7)$$

The relief factor essentially controls the rate at which the risks of entities degrade when left unobserved. The estimates $\hat{\mathbf{x}}'_{t+\tau|t+\tau}$ and $\mathbf{P}'_{t+\tau|t+\tau}$ give the risk estimates accounted for the scaling effect of the functional connectivity graph, and they can now be readily used for decision making concerning risks. As a rule of thumb, the value $\rho_r^* = 1 - 1/\lambda_{max}$ will theoretically ascertain that risks stay bounded where λ_{max} is the largest eigenvalue of $\mathbf{F}^{(t)}$. The larger the value of ρ_r , the faster the risk estimates will diminish. The value of the relief factor can be adjusted just like any other hyperparameter to meet the desired risk levels prior to testing. If no observations, $\mathbf{z}_t$, are provided, relative values of entity risks are conserved regardless of the value of the relief factor ρ_r .

4.2.4 Observability. The linear system formulation of risk estimation enables us to analyze the observability of the system, i.e., under what conditions will the risk estimates uniquely identify the actual risk distribution sought. In the absence of noise, this question of observability boils down to whether the observability grammian $\mathcal{O}_t^T \mathcal{O}_t$ in Equation (8) for the **linear time varying system (LTV)** has full rank [3, 40].

$$\begin{aligned}\mathcal{O}_t^T \mathcal{O}_t &= \mathbf{H}_0^T \mathbf{H}_0 + \sum_{k=1}^t \Phi_{k-1,0}^T \mathbf{H}_k^T \mathbf{H}_k \Phi_{k-1,0} \\ \Phi_{k,l} &= \prod_{j=l}^k \mathbf{F}^{(j)}, \quad k \geq l\end{aligned}\quad (8)$$

If the observability grammian in Equation (8) is of full rank, then the measurements uniquely identify the system state, which are the entity risks, in the absence of noise. This poses a necessary condition on the provided risk measurement, where we do not need to measure every entity at all times, but must have enough measurements to satisfy the full rank condition, or the internal state can only be identified up to the null space of the observability grammian. In the presence of noise, it is possible to get a similar condition for observability, referred to as “stochastic observability”, [5] which concerns the maximum singular value of the error covariance matrix $\mathbf{P}_{t|t}$:

$$\exists t_v \in \mathbb{R} : \quad \forall t \geq t_v, \quad \sigma_{max}(\mathbf{P}_{t|t}) < T_v. \quad (9)$$

Here T_v is a predefined threshold that bounds the largest singular value of the error covariance matrix and can be tuned on a case-by-case basis. Conditions Equations (8) and (9) can be used to test if the provided information to the risk estimation process is sufficient for the threat that is pursued.

4.3 Real Time Operation

A profound advantage of risk estimation over risk measurement is that estimation can be done as the network is observed, whereas measurements are much less frequent. In this section, the flowchart of the real-time operation of the proposed risk estimation system is outlined.

First, in order to reduce the possible computational overhead due to the size of the network, past representative flow data of the network is processed for the identification of related entity groups. The entity signals are formed as in Section 4.1.2, and then the functional connectivity graph for the whole network of interest is calculated as in Section 4.1.3. Then, the functional connectivity graph for the whole network is partitioned into non-overlapping groups of entities as described in Section 4.1.5, which defines the entity groups for the upcoming steps. This whole process is done

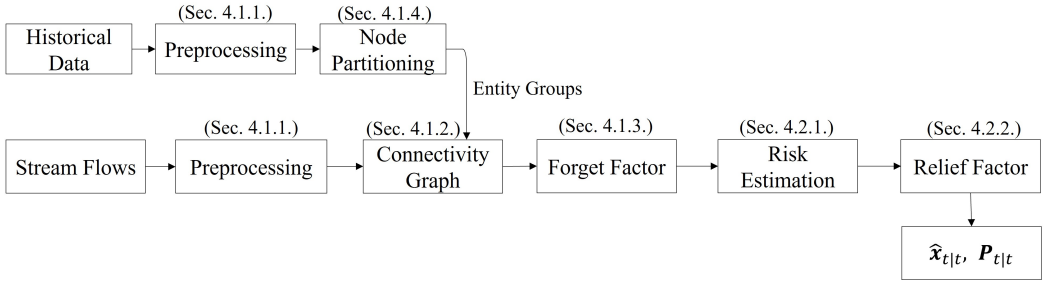


Fig. 7. Flow chart for real-time operation of *NRE*. The top row is done offline on a large set of past flows to infer entity communities. The bottom row computes the functional connectivity graph for the current time window and estimates the risks as flows occur. Related section numbers are given above each block.

offline, as denoted by the top row of Figure 7 and can be repeated as often as needed for dynamic networks.

Once entity groups of desirable size are obtained, their flows are then processed similarly, and current functional connectivity graphs for each cluster are calculated. Finally, for each entity cluster risk prediction and update according to the provided risk measurements are employed as in Section 4.2.1 independently, and this latter process is illustrated as the bottom row of Figure 7. Adequate node partitioning assures that the proposed method can be operated in real-time, where the scalability is discussed in Section 5.4.

5 Results and Discussion

The proposed risk estimation system has been experimented on a public dataset and is presented in this section. Most public datasets contain flow information and, occasionally, part of the network topology. However, risk measurements are problem-specific, and they are not commonly measured in gathering a dataset. The dataset used for testing is the CIC-IDS-2017 dataset [36, 37], which emulates a real-life network with benign network traffic and multiple attacks over 5 days. The benign traffic of this dataset was generated by realistic user profiles, and the attacks included common intrusions that aim at exploiting system vulnerabilities in order to gain leverage over the network for malicious purposes [37]. This dataset has been used as the benchmark for testing new risk measurement methods [10, 13, 43].

Section 5.1 demonstrates the resulting risk estimates over time with synthetic risk measurements. In Section 5.2, an example of possible network management action with the proposed risk estimates is illustrated. In Section 5.3, the effectiveness of the proposed risk estimates is compared with a risk measurement alternative, and finally, in Section 5.4, a running time analysis of the proposed system is presented.

5.1 Risk Estimates Over Time

Monday Session of the CIC-IDS-2017 dataset contains benign flows produced by the inner network that consists of servers, firewall, routers, switches, and users [37]. This session is used for illustrating the risk estimation procedure since it resembles common network connection data, and artificial measurements based on the provided network topology were added to analyze the results of the proposed risk estimation method.

In this part, the risk estimates for the inner network [37] are calculated for a brief time interval under normal operation of this network. In this illustration, the functional connectivity graph $\mathbf{F}^{(t)}$ is computed from the flows that are comprised of benign emulated user activity, and it is held fixed

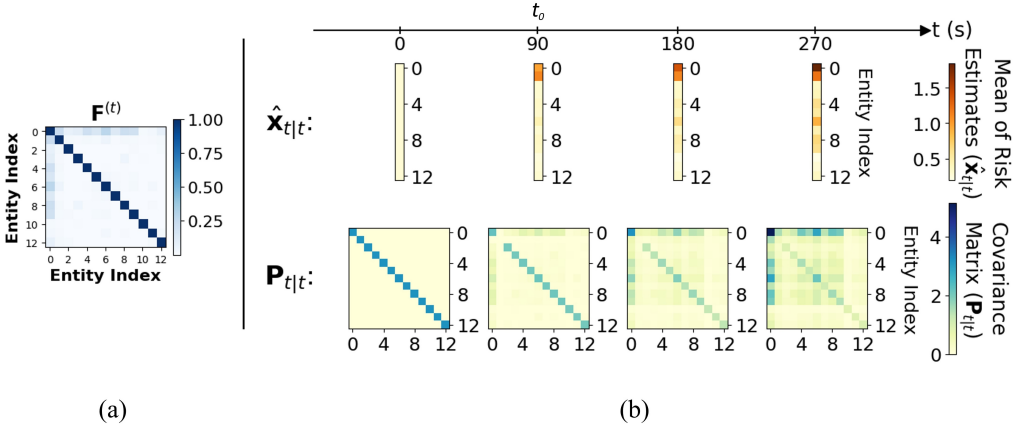


Fig. 8. Risk Estimates over time for the *Network Risk Estimation* system. (a) Functional Connectivity Graph $\mathbf{F}^{(t)}$ that is calculated from the flows of usual activity for this network and is held fixed during risk estimation. (b) Mean of risk estimates $\hat{\mathbf{x}}_{t|t}$ and covariance matrix $\mathbf{P}_{t|t}$ at the start of each synchronization time window. Low variance risk measurement is provided on entity one at time $t_0 = 90$ s, which appears as the small value in the diagonal of the risk estimate covariance matrix $\mathbf{P}_{t|t}$. Over time, the mean of the risk estimate $\hat{\mathbf{x}}_{t|t}$ converges to a state dictated by the functional connectivity graph $\mathbf{F}^{(t)}$.

during the risk estimation process for simplicity. Low uncertainty risk measurement of high-risk value is defined on the web server *192.168.10.50*, indexed as entity 1, at time instance $t_0 = 90$ s, and the relief factor is set slightly below the rule of thumb defined in Section 4.2.3. Snapshots of the calculated mean of relative risk estimates $\hat{\mathbf{x}}_{t|t}$ and their respective covariance matrices $\mathbf{P}_{t|t}$ are given in Figure 8(b).

Initially, the relative risk estimates were set to independent identically normal distribution $\mathcal{N}(c\mathbf{1}, \sigma^2\mathbf{I})$ with low risk mean c for each entity due to the lack of prior information about entity risks σ^2 being their variance. Single risk measurement was done at time instance $t_0 = 90$ s on entity 1 whose effect can be seen from 8(b) as high relative mean risk value for entity 1 and low variance, the (1,1) entry of risk the covariance matrix $\mathbf{P}_{t|t}$. After some time, the relative risk distribution converged to a stationary state given by the dominant eigenvector of the functional connectivity graph $\mathbf{F}^{(t)}$ since risk estimation without measurements simplifies to consecutive multiplication by the functional connectivity graph $\mathbf{F}^{(t)}$ that is also fixed. In this state, entity 0 with IP address *192.168.10.3*, which turns out to be the DNS server in this network topology [37], ends up having the highest risk due to its higher connectivity with other entities as seen from the functional connectivity graph $\mathbf{F}^{(t)}$ on Figure 8(a).

It is fair to say entity 0 has become the risk sink in this sub-network, which is along with our risk propagation intuition Equation (3) since it is influenced by many entities and risk estimation is dominated by the prediction step Equation (5) as opposed to the measurements. The variances of risk estimates, the diagonal values of the covariance matrix $\mathbf{P}_{t|t}$, in general increase over time due to successive prediction, and the only mechanisms that reduce these variances are the introduction of risk measurements or the risk relief controlled by the relief factor where both were present in this example.

All in all, probabilistic risk distributions described by $\hat{\mathbf{x}}_{t|t}$ and $\mathbf{P}_{t|t}$ carry all the information necessary to make decisions in this example since the prior risk distribution was specified as a Gaussian distribution. In the most general case, only the mean and covariance matrix of the prior

risk distribution still needs to be provided to the proposed system, which can be chosen as a uniform mean with some variance as in this example if no information is available regarding the prior risk distribution. Either way, the risk estimates are optimal among all linear estimators given the risk propagation model Equation (4).

As an example of utilization of these risk estimates in network management, $\hat{\mathbf{x}}_{t|t}$ can be used to spot the highest risk entity with the respective confidence given by $\mathbf{P}_{t|t}$. Alternatively, as illustrated in Section 5.2, routing on this network can be designed to minimize over estimated risks.

5.2 Simple Safe Routing

Another benefit of the proposed work *NRE* is that since it is a quantitative risk estimation method, decision-making and management of the network is straightforward after obtaining the risk estimates. One example is the “safe routing” design, which is to pick the route for packets to traverse in the network when any two entities are set to communicate. This section provides a simple safe-routing application by finding the best route for a pair of entities based on a security measure of paths in the network topology and the proposed entity risk estimates.

It is assumed that the underlying network topology is known; that is, for each entity, the entities that can be reached are given. Let the mean risk estimates at the current time be estimated. Then, intuitively, a user in the network will desire to avoid high-risk entities and prefer low-risk entities to route the desired packets over, as illustrated in Figure 2. Given the risk estimates, this objective can be formalized as minimizing a security loss over the available paths in the network topology, referred to as the *path risk*. Different security losses such as the *average mean risk of entities along the path* are reasonable, and the one that is chosen in this example is *maximum mean risk of entities along the path*. For this choice, the packets will be routed with the set of entities in the network for which all the mean risks are below a certain level, which is made as small as possible by the path choice. This path will be referred to as the *min-max path*. For the sub-network in Section 5.1, excluding the DNS server, the min-max path between a source and every other entity is computed, and the result is depicted in Figure 9.

Here, the leftmost entity *192.168.10.14* is the source from which all min-max paths are calculated. Every other entity is arranged according to its min-max path’s distance from the source, the path risks, and its IP address identifier beneath them. If the packets are desired to be sent to the entity *192.168.10.5*, then the green path in Figure 9 is the path with the least maximum risk, which is the choice for the simple safe routing problem.

In the identification of safe paths, only the mean of the risk estimates $\hat{\mathbf{x}}_{t|t}$ was used, and thus it was called the “simple safe routing”. In a more general setting, the risk distribution described by the error covariance matrix $\mathbf{P}_{t|t}$ can be utilized, and also, the objective loss that is to be minimized can be designed as a combination of path risk and round-trip time, signifying a tradeoff between security and packet delay.

Ultimately, this example illustrates a network management application of the proposed risk estimates, highlighting a way to add “security” aspect to a network function. With this addition, network decisions can be judged by previously unknown risks, and utility vs. security allotment can be quantitatively assessed. In the case of routing, in some cases, it might be desirable to sacrifice slightly from the round-trip delay to keep a path’s risk level lower. Having risk estimates described by $\hat{\mathbf{x}}_{t|t}$ and $\mathbf{P}_{t|t}$ enables this design. As for the implementation of this application, the difference between the observed network, given by the connection data, and the actual physical topology must be noted. Consequently, designing a policy based on the discovered *min-max path*, for the intermediate entities in the actual physical path, might be more suitable.

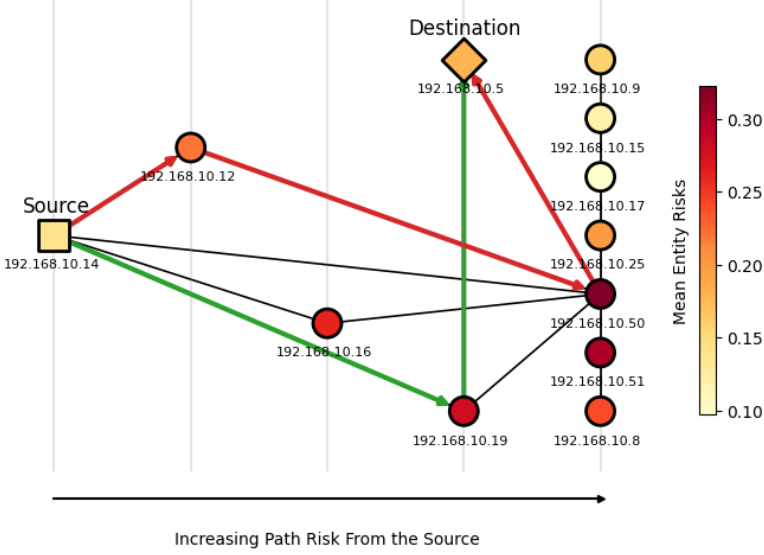


Fig. 9. A solved case of simple safe routing for the insider network of CIC-IDS-2017 [37]. Entities, with unique identifiers beneath, are sorted horizontally according to their min-max path's distance, called path risk. Node colors color-code the mean entity risks, and edges indicate the network topology or available paths. The green path is the min-max risk path between the source entity and the destination, and the red path is not since 192.168.10.50's risk is higher than every other entity in the green path.

5.3 Proof of Concept

The method outlined in Section 4 can be used to estimate the risks of individual entities that are not necessarily risk-measurable but are observable in terms of the connection data. A fair question is whether these risk estimates convey substantial information about the network state when the risk measurements are limited. In this section, the utility of these estimates is assessed by an experiment designed on multiple labelled datasets, CIC-IDS-2017 [36] and ToN-IoT [26].

The experiment is a binary classification problem of identifying the state of the network, whether malicious activity is present or not, labeled as *ATTACK* or *BENIGN* accordingly. The risk estimates obtained by the proposed method on the identified relevant part of the network have been compared with the limited risk measurements from a trained model on the flows of the insider network [37] for this binary classification problem.

5.3.1 Experimental Setup. For this experiment, the dataset is divided into chunks of flows consisting of consecutive flows in designated time windows for calculating the functional connectivity graph, $\mathbf{F}^{(t)}$, and the state of the network is assigned either as *ATTACK* if any of the flows are part of an attack or as *BENIGN* otherwise. The proposed risk estimation method is then deployed, producing entity risks without any measurements provided. The network is partitioned, as described in Section 4.1.5, according to the entity behaviors in the approximately the first day of the datasets. The subnetwork discovered by partitioning is then set as the EOI for the risk estimation process.

Each dataset is split into training, validation, and test sets for which the mean of entity-level risks is calculated for the available connection parameters, as detailed in Section 4, without any measurements provided. Then the risk estimate vector $\hat{\mathbf{x}}_{t|t} \in \mathbb{R}^n$, n being the EOI size, is used as a sample in n -dimensional feature space to train binary classifiers using three different generic

machine learning models of various complexity: Naive Bayes, Decision Trees, and Random Forest [30]. The experimental “Receiver Operating Characteristics” (ROC) curves of these classifiers are then obtained on the validation set, and the hyperparameters (i) synchronization window size δ , (ii) the window size τ for graph calculation, and (iii) the forget factor ρ_f are tuned via maximizing the “area under the curve (AUC)” performance metric, for the best classifier among the aforementioned models, on the validation set. The relief factor is not considered in tuning for this experiment since it has no effect on classification performance, but rather is just a scaling factor of the features due to the absence of risk measurements. An instance of ROC curves obtained on CIC-IDS-2017 dataset for the tuned proposed method (NRE) with “Number of Packets Received” connection parameter is given in Figure 11(a). The tuned hyperparameters are then used on the held out test session for the goodness assessment of the proposed risk estimates in network state inference. The goodness of inference on the train-validation set is judged by balanced accuracy, **true positive rate (TPR)** calculated as the percentage of correct inferences of network state when there was an attack present, and **false positive rate (FPR)** calculated as the false inferences when there were no attacks present.

The proposed method is compared with a representative of previous works in risk measurement, which was restricted to measurable entities. The previous work on network state inference considers various flow attributes and builds a model from these attributes for estimating the risk of the network as a whole [24, 43, 48]. In this experiment, this method is referred to as the “Flow-Based Network State Inference” method (FBNSI) due to its similarity with the flow-based risk measurement methods in Intrusion Detection literature [39]. To capture the limitations of the sole risk measurement methods in practice, flows of the FBNSI are constrained to the flows of the EOI in this experiment.

Previous work in risk measurement extracts information such as average round-trip delay, transmission rate, and response time [24] from flows to predict the risk of the whole network via predicting the likelihood of an attack. In contrast, the proposed system is designed to make use of per-entity attributes to estimate entity-level risks, which then tell about the network state. Consequently, in this experiment, the risk measurement method FBNSI is designed to make inferences, *BENIGN* or *ATTACK*, about the state of the network using the same time windows as the proposed method. In order to keep the information used about the flows same, the flow attributes are restricted to the same connection parameter used by the proposed method, e.g., the number of packets in forward and backward direction flow attributes are selected for the “Number of Packets Received” connection parameter. As a result, the feature space for the risk measurement method FBNSI is either one or two-dimensional, whose features correspond to the flow attribute used to generate the risk estimates by the proposed method.

Decisions are made about the network state with FBNSI method by first training the same classifiers on individual flows, which classify the individual flows themselves as either *benign flow* or *attack flow*. For the time window of flows over which the network state is sought, the flow-level decisions are aggregated by simply counting the *attack flow* percentage in the chunk. This percentage is assigned as the likelihood of the network state being *ATTACK*, which is used in inferring the state of the network. The whole network state inference process is summarized in Figure 10. Same metrics are used to judge inference performance on the train-validation set.

The only hyperparameter of this method is the time window size τ for network state estimation, which is determined after a similar tuning process on the training and validation sets. The training set ROC curves for the FBNSI method are obtained via thresholding the likelihood of network state on the validation set, which is shown in Figure 11(b) for the “Number of Packets Received” connection parameter on CIC-IDS-2017 dataset. For testing, the operating points for both methods are picked from the inferred curves as the points maximizing *balanced accuracy* classification metric, which corresponds to the 45° tangent to the ROC curves. Balanced accuracy has been chosen as the

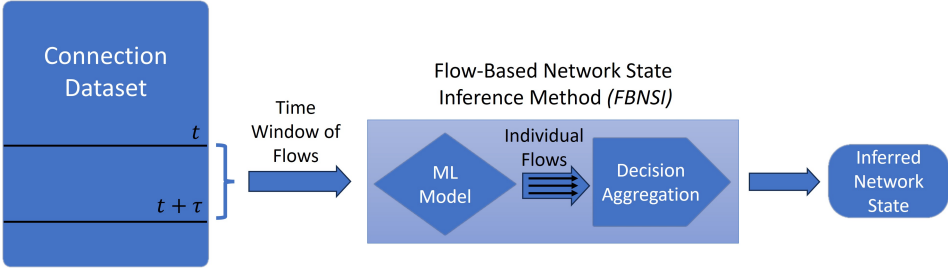


Fig. 10. Flowchart of the flow-based network state inference (*FBNSI*) method. Chunks of flows for the time window $[t, t + \tau]$ are fed into a Machine Learning model trained on individual flows. The decisions on the individual flows are aggregated by counting the percentage of flows labeled as *attack flow*, which determines the network state for the time window.

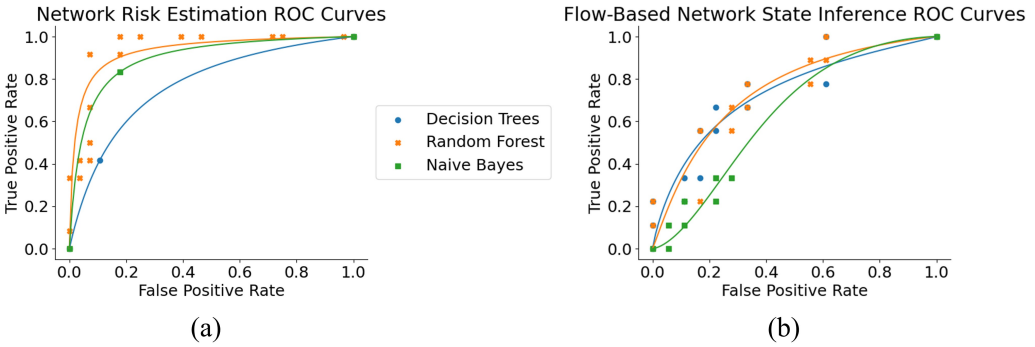


Fig. 11. Comparison of ROC curves on validation set for the *Number of Packets Received* connection parameter on CIC-IDS-2017 dataset. (a) Proposed Method *NRE*: Network state can be inferred with as good as 0.95 AUC (Area Under the Curve) when risks are estimated for the related part of the network. (b) Risk Measurement Method *FBNSI*, based on [24, 43, 48]: Network state inference is possible for the measurable part of the network but with lower performance with the best AUC being 0.77.

main classification performance metric on the test set as it accounted for the uneven distribution of classes, i.e., network states.

Finally, both methods are tested on the unseen test sets, and the peak balanced accuracy among the three classifiers used is reported for each method for clarity. The threats in this set ranged from web attacks such as *Brute Force*, *XSS*, *Sql Injection* and Distributed Denial of Service (DDoS) attacks [26, 37]. The testing was done using all available connection parameters except “Activation” since it was not available for *FBNSI* method. Figure 12 shows these peak balanced accuracy across different connection parameters for the CIC-IDS-2017 dataset, which reflect how the model would do if both methods modeled different aspects of flows. Finally, the Figure 13 summarizes the results of the network state inference problem in CIC-IDS-2017 and ToN-IoT datasets. In this figure, the distribution of best achievable performances, as outline in this section, for each method is shown across available connection parameters. The findings represented in Figure 13 isolate the effect of the underlying modeling paradigm as opposed to the classifier choice and flow aspects.

5.3.2 Analysis. The scatter points in Figure 11 are the training set operating points yielded by thresholding the likelihood of the positive class given by the two methods described. For visual interpretation, smooth non-linear curves have been fitted to the operating points obtained on the

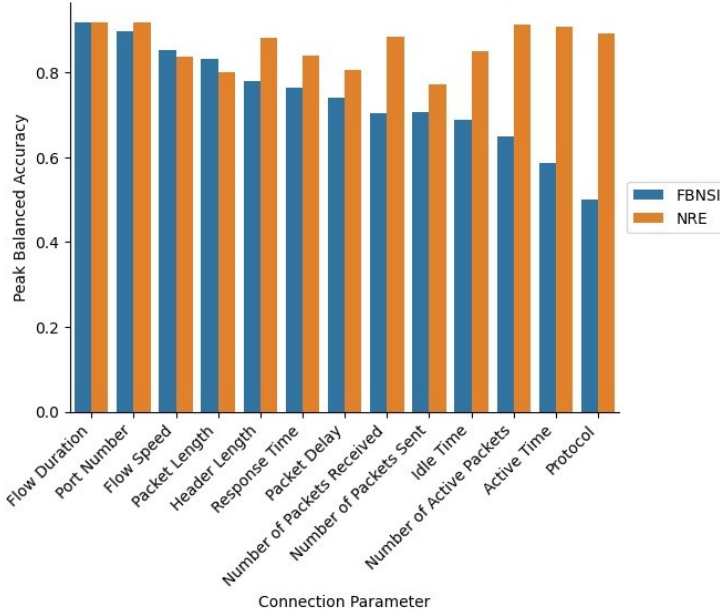


Fig. 12. Comparison of purely risk measurement approach *FBNSI* and proposed risk estimation method *NRE* across different connection parameters in terms of peak balanced accuracy. When risk measurements are descriptive of the network (connection parameters towards the left), the risk measurement approach is viable. However, when risk measurements are limited, *FBNSI* is not descriptive of the network. The proposed risk estimation approach *NRE* achieved more robust network state inference performance as flow information is restricted to different flow aspects.

validation set by fitting a line to the *logit* transform of both coordinates. Inferred ROC curves show how these models will perform if more data from the same distribution were tested.

For the test results, it is concluded from Figure 12 that not all aspects of connection data had substantial information about the network state for the risk measurement method *FBNSI*. We first note that, as control, when all the aspects of flows are considered, the inference performance of *FBNSI* was over 90%, reporting similar inference performance to previous work [24, 43, 46]. After the restriction on the flow aspects, connection parameters such as “Flow Duration” and “Port Number”, were sufficient in distinguishing the network state. This is in accordance with the nature of the threats present in this session [37]. However, there existed connection parameters such as “Active Time” and “Protocol” that were not informative about the network state. In other words, different connection parameters in this experiment represent varying degrees of risk measurement expressiveness, and the performance of the risk measurement paradigm depends on the amount of information the measurements have about the network state. In the case of limited risk measurements, the model does not provide valuable information about the network state.

With the addition of entity identity and the risk propagation model, the previously uninformative aspects of connection data become sufficient in inferring the network state. This is indicated as the consistently high peak balanced accuracy for *NRE* in Figure 12 for the CIC-IDS-2017 dataset, even when the method is restricted to a single flow aspect. In contrast, approaches that rely solely on local flow statistics exhibit wide variability across connection parameters, highlighting their dependence on particularly informative features.

This finding is corroborated by the results of the ToN-IoT dataset, where *NRE* significantly outperformed the *FBNSI* method when restricted to different flow aspects, as given shown in

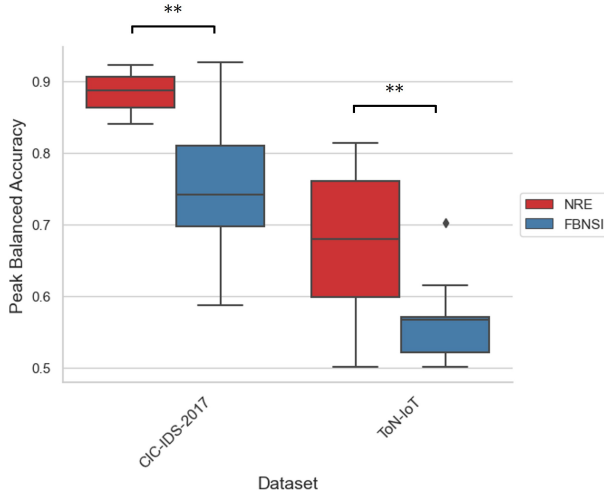


Fig. 13. Comparison of network state inference performances across datasets. For the case of limited flow information, risk estimation that employs risk propagation idea outperforms flow based methods with purely risk measurement approach. ** indicate $p\text{-val} < 0.01$.

Figure 13. The comparisons combining all available connection parameters were statistically significant, with $p < 0.01$ for t -test, confirming that the observed performance gains of *NRE* are robust and not due to chance. In other words, judging the network state by its entity's state and modeling their interactions as risk propagation enhances network visibility, particularly in regimes where individual flow-based risk measurements are weak or incomplete.

The experiment conducted on the CIC-IDS-2017 and ToN-IoT datasets indicated that the proposed entity risk estimation method is able to provide sufficient information needed for network state inference. Estimating the entity risks has made detecting abnormal network states easier, even if the available risk measurements were not substantial. The proposed risk estimates maintain the crucial information needed to make judgments about the network, such as intrusion detection, while carrying all the benefits of being a quantitative risk assessment tool so that it can readily be used in network management and decision-making.

5.4 Running Time Tests

One of the main advantages of risk estimation over risk measurement is operating in time scales that the device network might change. For this reason, it is desirable for the risk estimation system to have low running time complexity. Accordingly, the running time of the proposed risk estimation method has been analyzed over various design parameters on the same *Tuesday* session of the CIC-IDS-2017 dataset [36]. In this analysis, only the running time of calculation of the functional connectivity graph $\mathbf{F}^{(t)}$ using connection data is examined since the predict and update steps given by the Section 4.2.1 are just matrix multiplications that can be computed much faster than the aforementioned step. The experiments were conducted on Google Colaboratory environment [7] with CPU specifications being *dual-core Intel(R) Xeon(R) CPU @ 2.20GHz*.

First, the running time per connection window was tested with respect to both time windows, the signal synchronization window size δ , and graph window size τ as defined in Section 4.1. If the number of samples used to calculate a single edge weight in this graph is denoted as N , then it follows that $N = \lceil \tau/\delta \rceil$. A simple analysis of Equation (1) shows that the running time complexity of the calculation of a single edge in the connectivity graph is $\mathcal{O}(N)$ for the Pearson correlation

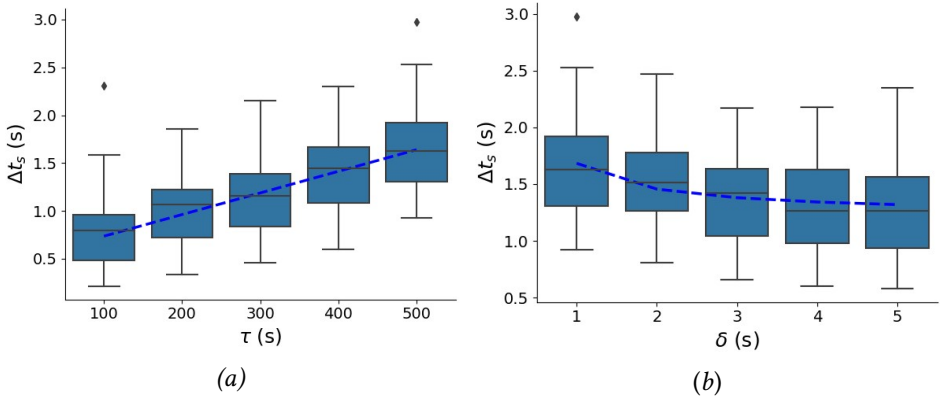


Fig. 14. (a) Simulation time vs. graph window size with 1s synchronization windows. Running time is proportional to the window size that is used to calculate the functional connectivity graph. (b) Simulation time vs. Synchronization Window size with 500s Graph Time Windows. Running time is inversely proportional to the window size that is used to aggregate flows to form the synchronous signals. For both cases, the simulation time $\Delta t_s \propto N$ where $N = \lfloor \tau / \delta \rfloor$ and the dotted line highlights this trend of the mean.

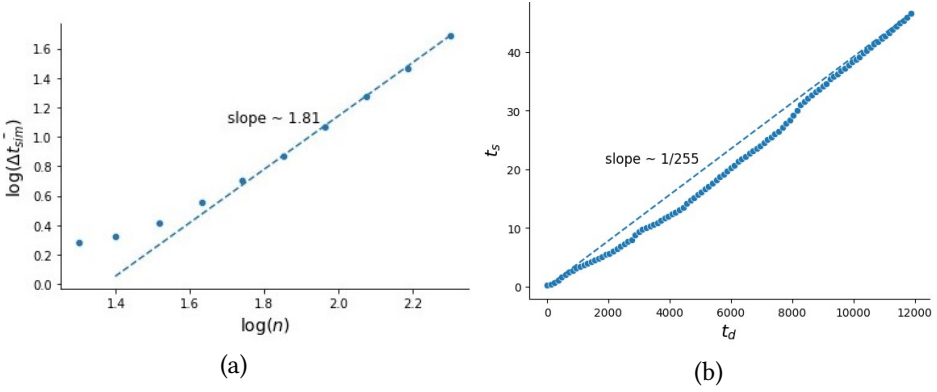


Fig. 15. (a) log average running time vs. log Number of Entities in the network of interest. A dashed line with slope 1.81 is the line fitted to the tail of the running times obtained, which implies an experimental bound on running time of $\mathcal{O}(n^{1.81})$. (b) Collection of time instances that mark the start of functional connectivity graph estimation in the dataset, t_d , and the respective recorded simulation times, t_s . The average slope of 1/255 indicates that 1 seconds of simulation time is able to cover 255 seconds of connection data, which is an indicator of real-time operability.

coefficient estimator, although it might be different for others estimators used to calculate the functional connectivity graph $F^{(t)}$. Figure 14 shows the simulation time it took to calculate a single connectivity graph $F^{(t)}$ for different time window sizes where the simulated running times are the box-plot, and the expected run-time is the dashed line.

The other parameter that crucially affects running time is the size of the network or the number of entities in the connectivity graph n . In calculating the graph $F^{(t)}$, each edge weight calculation is done separately, so the theoretical asymptotic behavior of the running time with respect to the size of the network is $\mathcal{O}(n^2)$ where the experiment showed even a tighter bound of $\mathcal{O}(n^{1.81})$ given by Figure 15(a).

Finally, for a particular parameter collection $(\tau, \delta, n) = (500s, 5s, 17)$ collection of timestamps at the start of the graph window in the dataset t_d and the simulation times t_s has been collected and is given in Figure 15(b). This plot has an average slope of about $1/255$, which indicates that 1 second of simulation time covers 255 seconds of flows in the dataset. The gain of 255 implies that real-time operation is possible for this parameter set.

For the real-time operation, it should be noted that parameter selection will be the deterministic factor for this gain. For instance, $\mathcal{O}(n^2)$ behavior in entity size implies that there will be a critical entity size n^* , with a simulation time to recording time gain of 1, beyond which no real-time operation will be possible. This scaling issue can be controlled by limiting the sub-network sizes in the node partitioning step in Section 4.1.5.

6 Conclusion

The risk measurement approach in cyber-network security is subject to loss in efficacy when the measurements are limited to a small subset of entities in the network and are coarse in time, both of which are common in practice. In this work, a risk estimation paradigm for cyber network security, NRE, is proposed as an alternative to existing solely risk measurement strategies. The proposed system NRE estimates the risks of entities based on their observed relationships in the connection data. For the case where risk measurements are available on some entities, the estimated risks are refined by the probabilistic framework using the optimal linear estimator. The end result of this system is the estimated risk distribution of the entities in terms of the mean estimate $\hat{x}_{t|t}$ and the respective error covariance matrix $P_{t|t}$, which carries all the information needed for active network management. The proposed system is fully data-driven as it does not need continuous human intervention, and it is adaptive to dynamic network environments where entity behavior might change over time.

A probabilistic risk framework has been defined for the threats associated with cyber networks. A risk estimation method is detailed in this work, estimating the proposed entity risks by utilizing available information on the cyber network. The limitations of the proposed method are discussed. The risk estimation process has been carried out on a sample network. A direct network security management application of the proposed risk estimates, called “simple safe routing”, is illustrated highlighting addition of security criteria to existing network functions through computed risk estimates. The proof of concept has been established on public datasets, where the risk estimation approach had significantly higher accuracy for the constrained network state inference problem. Finally, the real-time applicability of the proposed method was tested, which suggested that the online operation is possible with an appropriate choice of design parameters.

References

- [1] Olusola Akinrolabu, Jason R.C. Nurse, Andrew Martin, and Steve New. 2019. Cyber risk assessment in cloud provider environments: Current models and future needs. *Computers & Security* 87 (2019), 101600. DOI : <https://doi.org/10.1016/j.cose.2019.101600>
- [2] Sameer Hasan Albakri, Bharanidharan Shanmugam, Ganthan Narayana Samy, Norbik Bashah Idris, and Azuan Ahmed. 2014. Security risk assessment framework for cloud computing environments. *Security and Communication Networks* 7, 11 (2014), 2114–2124.
- [3] Brian D.O. Anderson and John B. Moore. 2005. *Optimal Filtering*. Courier Corporation.
- [4] Terje Aven. 2016. Risk assessment and risk management: Review of recent advances on their foundation. *European Journal of Operational Research* 253, 1 (2016), 1–13.
- [5] Vibhor L. Bageshwar, Demoz Gebre-Egziabher, William L. Garrard, and Tryphon T. Georgiou. 2009. Stochastic observability test for discrete-time Kalman filters. *Journal of Guidance, Control, and Dynamics* 32, 4 (2009), 1356–1370.
- [6] Arda Bayer. 2026. *Network Risk Estimation (NRE)*. DOI : <https://doi.org/10.5281/zenodo.21520902>
- [7] Ekaba Bisong. 2019. *Building Machine Learning and Deep Learning Models on Google Cloud Platform: A Comprehensive Guide for Beginners*. Apress Berkeley, CA, Berkeley, CA. 59–64 pages. DOI : <https://doi.org/10.1007/978-1-4842-4470-8>

- [8] Robert G. Brown and Patrick Hwang. 1992. *Introduction to Random Signals and Applied Kalman Filtering*. New York, John Wiley & Sons, Inc., 1992. 512, New York, NY.
- [9] S. Sreenivasa Chakravarthi and Sakkaravarthi Ramanathanb. 2016. Monitoring cloud services exploitation using heterogeneous network flowdata analysis. *International Journal of Control Theory and Applications* 9, 51 (2016), 299–309.
- [10] Liyan Chang and Paula Branco. 2021. Graph-based Solutions with Residuals for Intrusion Detection: the Modified E-GraphSAGE and E-ResGAT Algorithms. *arXiv preprint arXiv:2111.13597* [cs.CR].
- [11] Lu Chen, Tao Zhang, Yuanyuan Ma, Yong Li, Chen Wang, Chuan He, Zhuo Lv, and Nuannuan Li. 2024. A bayesian-attack-graph-based security assessment method for power systems. *Electronics* 13, 13 (2024), 2628.
- [12] Cisco. 2023. Cisco Secure Network Analytics (Stealthwatch) - Cisco Security Analytics [White paper]. Retrieved from <https://www.cisco.com/c/en/us/products/collateral/security/stealthwatch/white-paper-c11-740605.html>
- [13] Luis Filipe Dias and Miguel Correia. 2020. Big data analytics for intrusion detection: an overview. *Handbook of Research on Machine and Deep Learning Applications for Cyber Security* (2020), 292–316.
- [14] Sarah Elder, Md. Rayhanur Rahman, Gage Fringer, Kunal Kapoor, and Laurie Williams. 2024. A survey on software vulnerability exploitability assessment. *Comput. Surveys* 56, 8 (2024), 1–41.
- [15] Daji Ergu, Gang Kou, Yong Shi, and Yu Shi. 2014. Analytic network process in risk assessment and decision analysis. *Computers & Operations Research* 42 (2014), 58–74.
- [16] Sreenivasulu Gajula. 2024. Cybersecurity risk prediction using graph neural networks. *Journal of Information Systems Engineering and Management* 9, 4s (2024).
- [17] Clark Glymour, Kun Zhang, and Peter Spirtes. 2019. Review of causal discovery methods based on graphical models. *Frontiers in Genetics* 10, Article 524 (2019).
- [18] Lars Hagen and Andrew B. Kahng. 1992. New spectral methods for ratio cut partitioning and clustering. *IEEE Transactions on Computer-Aided Design of Integrated Circuits and Systems* 11, 9 (1992), 1074–1085.
- [19] Rick Hofstede, Pavel Čeleda, Brian Trammell, Idilio Drago, Ramin Sadre, Anna Sperotto, and Aiko Pras. 2014. Flow monitoring explained: From packet capture to data analysis with netflow and ipfix. *IEEE Communications Surveys & Tutorials* 16, 4 (2014), 2037–2064.
- [20] Steve Horvath. 2011. *Weighted Network Analysis: Applications in Genomics and Systems Biology*. Springer Science & Business Media, Los Angeles, CA.
- [21] International Organization for Standardization. 2018. ISO 31000: Risk Management—Guidelines. Retrieved from <https://www.iso.org/obp/ui#iso:std:iso:31000:ed-2:v1:en>
- [22] Harjinder Singh Lallie, Kurt Debattista, and Jay Bal. 2020. A review of attack graph and attack tree visual syntax in cyber security. *Computer Science Review* 35, Article 100219 (2020).
- [23] Arash Habibi Lashkari, Gerard Draper Gil, Mohammad Saiful Islam Mamun, and Ali A. Ghorbani. 2017. Characterization of tor traffic using time based features. In *Proceedings of the 3rd International Conference on Information Systems Security and Privacy - Volume 1: ICISPP*. INSTICC, SciTePress, Porto, Portugal, 253–262. DOI: <https://doi.org/10.5220/0006105602530262>
- [24] Qianmu Li, Youhui Tian, Qiang Wu, Qi Cao, Haiyuan Shen, and Huaqiu Long. 2020. A cloud-fog-edge closed-loop feedback security risk prediction method. *IEEE Access* 8 (2020), 29004–29020.
- [25] David A. Maluf, Raghuram S. Sudhaakar, and Kim-Kwang Raymond Choo. 2018. Trust erosion: Dealing with unknown-unknowns in cloud security. *IEEE Cloud Computing* 5, 4 (2018), 24–32.
- [26] Nour Moustafa. 2021. A new distributed architecture for evaluating AI-based security systems at the edge: Network TON_IoT datasets. *Sustainable Cities and Society* 72, Article 102994 (2021).
- [27] Luis Muñoz-González and Emil C. Lupu. 2016. Bayesian attack graphs for security risk assessment. In *IST-153 Workshop on Cyber Resilience*.
- [28] Shishir Nagaraja. 2014. Botyacc: Unified p2p botnet detection using behavioural analysis and graph analysis. In *European Symposium on Research in Computer Security*. Springer, Cham, 439–456.
- [29] Xinming Ou and Anoop Singhal. 2011. *Quantitative Security Risk Assessment of Enterprise Networks*. Springer, New York, NY.
- [30] F. Pedregosa, G. Varoquaux, A. Gramfort, V. Michel, B. Thirion, O. Grisel, M. Blondel, P. Prettenhofer, R. Weiss, V. Dubourg, et al. 2011. Scikit-learn: Machine learning in python. *Journal of Machine Learning Research* 12, 85 (2011), 2825–2830.
- [31] Christopher J. Quinn, Todd P. Coleman, Negar Kiyavash, and Nicholas G. Hatsopoulos. 2011. Estimating the directed information to infer causal relationships in ensemble neural spike train recordings. *Journal of Computational Neuroscience* 30, 1 (2011), 17–44.
- [32] Patricia A.S. Ralston, James H. Graham, and Jefferey L. Hieb. 2007. Cyber security risk assessment for SCADA and DCS networks. *ISA Transactions* 46, 4 (2007), 583–594.
- [33] Alex Ramos, Marcella Lazar, Raimir Holanda Filho, and Joel J.P.C. Rodrigues. 2017. Model-based quantitative network security metrics: A survey. *IEEE Communications Surveys & Tutorials* 19, 4 (2017), 2704–2734.

- [34] Prasad Saripalli and Ben Walters. 2010. Quirc: A quantitative impact and risk assessment framework for cloud security. In *2010 IEEE 3rd International Conference on Cloud Computing*. IEEE, Miami, FL, 280–288.
- [35] Alireza Shameli Sendi and Mohamed Cheriet. 2014. Cloud computing: A risk assessment model. In *2014 IEEE International Conference on Cloud Engineering*. IEEE, Boston, MA, 147–152. DOI : <https://doi.org/10.1109/IC2E.2014.17>
- [36] Iman Sharafaldin, Arash Habibi Lashkari, and Ali Ghorbani. 2018. Intrusion detection evaluation dataset (CIC-IDS2017) [Dataset]. Retrieved from <http://www.unb.ca/cic/datasets/IDS2017.html>
- [37] Iman Sharafaldin, Arash Habibi Lashkari, and Ali Ghorbani. 2018. Toward generating a new intrusion detection dataset and intrusion traffic characterization. In *4th International Conference on Information Systems Security and Privacy (ICISSP 2018)*. ICISSP, Madeira, Portugal, 108–116. DOI : <https://doi.org/10.5220/0006639801080116>
- [38] Dan Simon. 2006. *Optimal State Estimation: Kalman, H Infinity, and Nonlinear Approaches*. John Wiley & Sons, Hoboken, NJ.
- [39] Anna Sperotto, Gregor Schaffrath, Ramin Sadre, Cristian Morariu, Aiko Pras, and Burkhard Stiller. 2010. An overview of IP flow-based intrusion detection. *IEEE Communications Surveys & Tutorials* 12, 3 (2010), 343–356.
- [40] Robert F. Stengel. 1994. *Optimal Control and Estimation*. Courier Corporation.
- [41] Denis Verdon and Gary McGraw. 2004. Risk analysis in software design. *IEEE Security & Privacy* 2, 4 (2004), 79–84.
- [42] Zhe Wang, Ahmed Alahmadi, David Zhu, and Tongtong Li. 2015. Brain functional connectivity analysis using mutual information. In *2015 IEEE Global Conference on Signal and Information Processing (GlobalSIP)*. IEEE, Orlando, FL, 542–546.
- [43] Junrui Wu, Wenyong Wang, Lisheng Huang, and Fengjun Zhang. 2022. Intrusion detection technique based on flow aggregation and latent semantic analysis. *Applied Soft Computing* 127, Article 109375 (2022).
- [44] Kongpei Wu, Huiqin Qu, and Conggui Huang. 2023. A network intrusion detection method incorporating Bayesian attack graph and incremental learning part. *Future Internet* 15, 4 (2023), 128.
- [45] Joseph Young, Curtis L. Neveu, John H. Byrne, and Behnaam Aazhang. 2021. Inferring functional connectivity through graphical directed information. *Journal of Neural Engineering* 18, 4 (2021), 046019.
- [46] Arif Yulianto, Parman Sukarno, and Novian Anggis Suwastika. 2019. Improving adaboost-based intrusion detection system (IDS) performance on CIC IDS 2017 dataset. In *Journal of Physics: Conference Series*, Vol. 1192. IOP Publishing, 012018.
- [47] Meihui Zhong, Mingwei Lin, Chao Zhang, and Zeshui Xu. 2024. A survey on graph neural networks for intrusion detection systems: Methods, trends and challenges. *Computers & Security* 141, Article 103821 (2024).
- [48] Chao Zhou, Yajuan Guo, Wei Huang, Jing Guo, and Daohua Zhu. 2016. Network security risk prediction based on time-varying markov model. In *Proceedings of the 2016 4th International Conference on Mechanical Materials and Manufacturing Engineering*. Atlantis Press, Wuhan, China, 212–215. DOI : <https://doi.org/10.2991/mmme-16.2016.49>

Appendix

A Derivation of Optimal Linear Risk Estimator

In this section, a derivation of the optimal risk estimator is presented, assuming the risk propagation model given in Equation (3). The result is the discrete Kalman Filter applied for the risk estimation problem. The system and measurement model is given in Equation (4), which is based on Equation (3) with the process and measurement noise modeled. The goal is to find the unbiased linear estimator with **minimum mean square error (MMSE)** for the model in Equation (4) given the risk measurements up to the current time t . This is also the optimal estimator when risks $\mathbf{x}_t$ are Gaussian.

Let $\hat{\mathbf{x}}_{t|t}$ be the best-unbiased estimate of the risks at time t in the MMSE sense. It can be easily shown that this best estimate, in the MMSE sense, is the conditional expectation of the risks conditioned on the measurements up to time t [8]:

$$\hat{\mathbf{x}}_{t|t} = \mathbb{E}[\mathbf{x}_t | \mathbf{z}_0^t]. \quad (10)$$

Here, $\mathbf{z}_0^t = \{\mathbf{z}_0, \dots, \mathbf{z}_t\}$ is the collection of discrete risk measurements starting from time 0, which is the reference point in time when the first measurement was made. The risk estimate $\hat{\mathbf{x}}_{t|t}$ then has the error covariance matrix $\mathbf{P}_{t|t}$:

$$\mathbf{P}_{t|t} = \mathbb{E}[(\mathbf{x}_t - \hat{\mathbf{x}}_{t|t})(\mathbf{x}_t - \hat{\mathbf{x}}_{t|t})^T | \mathbf{z}_0^t] \quad (11)$$

Let $\hat{\mathbf{x}}_{t+\tau|t}$ be the best estimator after a time window of length τ , given the measurements up to time t . Then similarly using system model in Equation (4) it can be shown that [38],

$$\hat{\mathbf{x}}_{t+\tau|t} = \mathbf{F}^{(t)} \hat{\mathbf{x}}_{t|t}. \quad (12)$$

This estimator in Equation (12) is also known as the *a priori* estimate since the current measurement $\mathbf{z}_{t+\tau}$ has not been accounted for yet. Similarly, the prior estimate covariance matrix can be calculated as [38]:

$$\mathbf{P}_{t+\tau|t} = \mathbf{F}^{(t)} \mathbf{P}_{t|t} \mathbf{F}^{(t)T} + \mathbf{Q}_t. \quad (13)$$

Equations Equations (12) and (13) are known as the predict steps. In accounting for the effect of new observations about current risks, an *unbiased* linear estimator is sought, which can be shown to have the following form [8]:

$$\begin{aligned} \hat{\mathbf{x}}_{t+\tau|t+\tau} &= \hat{\mathbf{x}}_{t+\tau|t} + \mathbf{K}_{t+\tau} \mathbf{v}_{t+\tau} \\ \mathbf{v}_{t+\tau} &= \mathbf{z}_{t+\tau} - \mathbf{H}_{t+\tau} \hat{\mathbf{x}}_{t+\tau|t} \end{aligned} \quad (14)$$

Here, the variable $\mathbf{v}_{t+\tau}$ is referred to as *innovation* since it represents the difference between actual measurement $\mathbf{z}_{t+\tau}$ and the predicted measurement $\mathbf{H}_{t+\tau} \hat{\mathbf{x}}_{t+\tau|t}$ based on the knowledge up to time step t . $\mathbf{K}_{t+\tau}$ is the gain matrix for innovation which controls the contribution of measurements versus the previous estimate. Equation (14) describes a set of linear estimators. As the final step, the value of the gain matrix is specified by the MMSE criteria:

$$\mathbf{K}_{t+\tau}^* = \arg \min_{\mathbf{K}_{t+\tau}} \mathbb{E}[(\mathbf{x}_{t+\tau} - \hat{\mathbf{x}}_{t+\tau|t+\tau})^T (\mathbf{x}_{t+\tau} - \hat{\mathbf{x}}_{t+\tau|t+\tau}) | \mathbf{z}_0^{t+\tau}] \quad (15)$$

Minimization has a closed-form solution which is known as the *Kalman Gain* [38]:

$$\begin{aligned} \mathbf{K}_{t+\tau}^* &= \mathbf{P}_{t+\tau|t} \mathbf{H}_{t+\tau}^T \mathbf{S}_{t+\tau}^{-1} \\ \mathbf{S}_{t+\tau} &= \mathbf{H}_{t+\tau} \mathbf{P}_{t+\tau|t} \mathbf{H}_{t+\tau}^T + \mathbf{R}_{t+\tau} \end{aligned} \quad (16)$$

The matrix $\mathbf{S}_{t+\tau}$ in Equation (16) is the *innovation variance* and it can be shown that $\mathbf{S}_{t+\tau} = \mathbb{E}[\mathbf{v}_{t+\tau} \mathbf{v}_{t+\tau}^T]$. Combining with Equation (14) the error covariance matrix $\mathbf{P}_{t+\tau|t+\tau}$ of the *a posteriori* estimate $\hat{\mathbf{x}}_{t+\tau|t+\tau}$ can be obtained [38]:

$$\mathbf{P}_{t+\tau|t+\tau} = \mathbf{P}_{t+\tau|t} - \mathbf{K}_{t+\tau}^* \mathbf{S}_{t+\tau} \mathbf{K}_{t+\tau}^{*T} \quad (17)$$

Together Equations (14), (16) and (17) are the update equations for the risk estimates. The derivation done here yields the best risk estimate, in the MMSE sense, among all linear estimators, and it can be shown that if $\mathbf{x}_t$ is Gaussian distributed, this estimator is the best among all estimators, linear and non-linear included [8].

Received 29 January 2025; revised 19 February 2026; accepted 11 July 2026